

申请上海交通大学硕士学位论文

基于智能卡的身份认证和访问控制

姓 名：张帆

指导老师：张申生

学 校：上海交通大学

院 系：信息安全工程学院

班 级：B0103691

学 号：1010369041

二零零四年一月一日

Thesis submitted to
Shanghai Jiao Tong University
For the degree of Master in Computer Science

**Identity Authentication and Access Control
Based On Smart Card**

Candidate: Zhang Fan
Supervisor: Professor Zhang Shensheng

Information Security Engineering College
Shanghai Jiao Tong University

Jan, 2004

基于智能卡的身份认证和访问控制

摘 要

智能卡技术是一种通过基于内置 CPU 和存储器来进行数据存储, 运算和加密的技术。随着现代电子技术的飞速发展, 智能卡技术已经日臻成熟, 功能日益强大。近年来, 基于智能卡的运用和开发发展迅速。智能卡在现代社会中越来越受到广大用户的青睐。

目前, 智能卡运用的一个重要领域就是与已有信息安全技术手段的结合和在此基础上的拓展。身份认证和访问控制是一个比较复杂的安全课题, 目前, 直接针对该领域的研究已经有一定的发展, 但是还不够深入。随着智能卡技术本身的不断进展, 身份认证和访问控制技术一方面有了更大的发展空间, 另一方面也不断的提出新的问题。基于智能卡的身份认证和访问控制是智能卡技术、身份认证技术和访问控制技术的综合运用, 且直接影响到智能卡的实用与推广, 因而具有相当重要的理论和实践意义。

作者在大量工程实践基础上, 提出特定于 Windows 系统的基于智能卡的身份认证和访问控制。在可预见的将来, 基于智能卡的身份认证和访问控制技术可以在改善操作系统与网络的安全性能方面起到有效作用。本文的主要工作可以总结如下:

1. 提出选用内置用户名和密码的登录措施, 并扩展使用公钥证书来代替传统的用户名和密码方式。
2. 设计与实现了基于智能卡的安全登录系统, 重点讨论了客户端图形化交互界面 GINA, 它对智能卡的运用, 采用一系列身份认证技术, 有效地避免非授权用户对于计算机资源的非法访问, 从而使操作系统的安全性得到改善。
3. 提出了智能卡插拔锁定以及管理员身份认证等具体实现方法

本项研究已经在上海慧勤信息技术有限公司的 SecureLogon2003 系统上得到了应用, 具有一定的实用和创新价值。

关键字: 智能卡, 身份认证, 访问控制, GINA

Identity Authentication and Access Control

Based On Smart Card

ABSTRACT

Smart Card is a technique that uses the embedded CPU and storage to data operation and encryption. With the rapid development of modern electronic technology, smart card shows a more powerful use in future. In recent years, the use and development of smart cards is increasing. Smart card tends to be accepted by more and more users in modern society.

At present, one important research area in smart card is to combine it with current information security technologies and to extend it. And the identity authentication and access control is a complex issue on security. The research on this area has developed to some extent, however, it can still be furthered. On the one hand, coming up with the development of smart card, identity authentication and access control technique has more space to go on. On the other hand, it introduces new problems. The identity authentication and access control based on smart card is the combination of smart card, authentication and access control technologies, which directly affect the use and spread of smart card. In conclusion, all these researches are quite important and practical.

Based on his former work, the author proposed a technique of the identity authentication and access control based on smart card which is specific for the Windows operating systems. This technique could be used to improve the security of operating systems and network. The main work of this thesis is as follows:

1. Provide the method for system logon with username and password stored in smart card, especially extending the use of the certification to replace the traditional logon method via username and password.
2. Design and implement a secure logon system based on smart card, and put the emphasis on discussing Graphical Identification and Authentication (GINA) which uses smart card and other identification technologies to avoid the unallowed entry towards the computer resources and to improve the security of operating systems.

3. Provide an implement method in the smart card insert and removal, workstation lock and the administrator identity authentication.

This research has been implemented on the project: SecureLogon 2003 of Shanghai HiQ Company. It has a value of innovation in some sense.

KEY WORDS: Smart Card, Authentication, Access Control, GINA

目 录

第一章 绪论.....	1
1.1 课题背景和研究现状.....	1
1.2 智能卡简介.....	1
1.2.1 传统意义上的智能卡——IC 卡	1
1.2.2 Windows 平台上的智能卡——Smart Card	2
1.2.3 智能卡应用与前景.....	3
1.3 主要研究内容.....	3
1.3.1 身份认证机制.....	3
1.3.1.1 基于 DCE/Kerberos 的认证机制	3
1.3.1.2 基于公共密钥的认证机制.....	3
1.3.1.3 基于挑战/应答的认证机制.....	4
1.3.2 访问控制技术.....	4
1.3.2.1 入网访问控制.....	4
1.3.2.2 权限控制.....	4
1.3.2.3 目录级安全控制.....	4
1.3.2.4 属性安全控制.....	5
1.3.2.5 服务器安全控制.....	5
1.3.3 活动目录技术.....	5
1.3.4 证书管理技术.....	5
1.4 论文章节安排.....	6
第二章 Windows 下的智能卡技术.....	8
2.1 智能卡技术概述.....	8
2.1.1 支持智能卡的策略.....	8
2.1.2 支持智能卡的方法.....	8
2.3 Microsoft 产品中的智能卡支持	9
2.3.1 智能卡子系统的体系结构.....	9
2.3.2 服务提供程序.....	9
2.3.3 资源管理器.....	9
2.3.4 设备驱动程序.....	9
2.3.5 读卡器驱动程序库.....	10
2.4 Windows2000 中的智能卡功能.....	10
2.4.1 客户身份验证.....	10
2.4.2 公钥交互登录.....	10
2.4.3 安全电子邮件.....	11
第三章 密码学基础——PKI 和证书	12
3.1 PKI 简介.....	12
3.2 数字证书.....	12
3.3 PKI 核心——认证中心.....	13

3.3.1 认证中心 CA 简介.....	13
3.3.2 CA/RA 简介.....	14
3.3.3 认证中心的功能.....	15
第四章 身份认证和访问控制技术.....	16
4.1 身份认证协议.....	16
4.1.1 Kerberos 认证体制.....	16
4.1.2 SSL 协议.....	17
4.1.3 CA 证书.....	17
4.1.4 X.509 数字证书.....	19
4.2 常用的用户身份识别方法.....	20
4.2.1 传统的用户身份识别方法.....	20
4.2.2 基于智能卡的用户身份识别方法.....	20
4.3 访问控制简介.....	21
4.3.1 访问控制的定义.....	21
4.3.2 访问控制分类.....	21
4.3.2 Windows2000 访问控制原理.....	22
第五章 基于智能卡的安全登录系统的设计.....	25
5.1 Winlogon 和 GINA 简介.....	25
5.2 Windows2000 身份认证技术分析.....	26
5.3 系统整体设计.....	28
5.4 客户端的设计.....	29
5.5 服务器端的设计.....	30
第六章 基于智能卡的安全登录系统的实现.....	32
6.1 HiQ SecureLogon 简介.....	32
6.2 客户端 GINA 部分实现说明.....	33
6.2.1 函数说明.....	33
6.2.2 系统整体流程说明.....	37
6.2.3 登录流程说明.....	37
6.2.4 解锁流程说明.....	40
6.2.5 字符串处理.....	41
6.2.6 智能卡检测窗口和插拔锁定.....	42
6.2.7 管理员身份检测和权限分配.....	44
6.2.8 GINA 安装.....	46
6.3 服务器端 SLogonConsole 部分实现说明.....	46
第七章 总结与展望.....	49
参考文献.....	50
致 谢.....	51
攻读硕士学位期间的科研与学术论文.....	52

第一章 绪论

1.1 课题背景和研究现状

随着现代电子技术的飞速发展,智能卡应运而生。经过广大电子工作者和计算机专业人员的潜心钻研和不懈努力,智能卡技术日臻成熟,功能日益强大。目前,它已作为一种安全、方便、快捷的支付工具和轻便、详实的个人信息资料库,在现代社会中越来越受到广大用户的青睐。因此,深入探索智能卡技术、不断发掘和拓广其应用领域已为计算机同行们悉心钻研的热门课题。已经有相当的计算机工作者开始把智能卡技术运用到计算机行业的各个行业,这其中包含了身份认证和访问控制领域。

身份认证和访问控制是一个比较复杂的课题,目前,国际上直接针对该领域的研究已经有一定的发展,但是还不够深入。同时,随着智能卡技术本身的不断进展,身份认证和访问控制技术既有了更大的发展空间,也不断的提出新的问题。基于智能卡的身份认证和访问控制是智能卡技术,身份认证技术和访问控制技术地综合运用,且直接影响到智能卡的实用与推广,因而具有相当重要的理论和实践意义。

目前,专门针对智能卡的性能研究以及针对网络身份验证和访问控制的性能研究都已经积累了一定的经验和基础。但是目前极少有已发表的专门针对智能卡的身份验证和访问控制技术的文献。本文作者在上海交通大学计算机集成制造实验室主持的 SLogon 安全项目中进行了较为深入的理论与工程实践,并于其他同事合作完成了 SLogon 安全登录系统和 SLogonConsole 智能卡及账号管理系统等部分的研发工作,并据此提出与实现了基于智能卡的身份验证和访问控制技术。在智能卡技术的可预见的快速发展的未来,基于智能卡的身份验证和访问控制技术都可以在提高系统安全性能等方面起到有效作用。

1.2 智能卡简介

1.2.1 传统意义上的智能卡——IC 卡

大多数人对智能卡的印象是一个形状与信用卡类似的矩形塑料片,这种通常意义上的智能卡又称集成电路卡(Integrated Circuit Card)即 IC 卡,它将一个集成电路芯片镶嵌在塑料基片中,封装成卡的形式。IC 卡芯片具有写入数据和存储数据的能力,IC 卡存储器中的内容根据需要可以有条件地供外部读取或供内部信息处理和判断之用,根据卡中所镶嵌的集成电路的不同,IC 卡可以分成三类:

- 1) 存储器卡:卡中的集成电路为 EEPROM(可用电擦除的可编程只读存储器)

- 2) 逻辑加密卡:卡中的集成电路具有加密逻辑和 EEPROM
- 3) CPU 卡:卡中的集成电路包括中央处理器 CPU、EEPROM、随机存储器 RAM 以及固化在只读存储器 ROM 中的片内操作系统 COS(Chip Operating System)

严格来讲,只有 CPU 卡才是真正的 IC 卡,但在实际中,把上述三种卡都称为 IC 卡。虽然多数情况下智能卡是以 IC 卡的形式出现,但是智能卡也有许多其它的形式,其中包括:

- 1) 信用卡
- 2) 钥匙状令牌
- 3) GSM 移动电话中的 SIM 芯片

智能卡中包括一个内置的处理器,并且是可编程的。智能卡能够安全地存储数据,这些数据包括私钥和公钥证书。

1.2.2 Windows 平台上的智能卡——Smart Card

本文中所讲述的智能卡与通常所见的智能卡类似,但是它不是传统意义上的基于读卡器的 IC 卡,而是基于 Windows 的即插即用 USB 智能卡。



图 1-1 智能卡示意图

智能卡是 Microsoft 集成到 Windows 平台中的公钥基础结构的关键组件,原因是智能卡能够加强纯软件的解决方案,如客户身份验证、登录和安全电子邮件。智能卡实际上是公钥证书和相关密钥的结合,因为它们:

- 为保护私钥和其他形式的个人信息提供了防篡改的存储。
- 可隔离重要的安全计算,包括身份验证、数字签名以及与其他不需了解的系统部分之间的密钥交换。
- 使办公室、家中或途中计算机之间的凭据和其他私人信息具有可携带性。

智能卡提供了令人满意的新功能,这如同引入鼠标或 CD 一样为计算机产业带来了一场革命,因而智能卡必将成为 Windows 平台不可分割的一部分。

1.2.3 智能卡应用与前景

智能卡在制造和使用过程中采用了很多措施保证其安全性。比如在智能卡的制造过程中使用特定而昂贵的生产设备,采用一些特定的技术;对智能卡在制造和发行过程中所使用的一切参数都严格保密;增强智能卡在包装上的完整性;在智能卡的内部安装监控程序,以防止对处理器/存储器数据总线及地址总线的截听。可使用生物鉴别方法和利用人的下意识特征进行验证。在智能卡与外部设备进行信息交换时,可使用加密算法(如 DES、RSA 等)、数字签名等保证其安全性。

智能卡的存储容量大,可靠性和安全性高,携带方便,已经在很多领域获得了广泛的应用。智能卡的应用可分为金融系统应用和非金融系统应用两大类。智能卡在金融领域的一个重要应用就是作为信用卡使用。信用卡主要由银行发行和管理,持卡人用它作为消费时的支付工具,可以使用预先设定的透支限额资金。持卡人持卡消费时首先要确认其合法身份,然后判断额度,决定是否可进行该次消费,最后才能消费,消费完后要把持卡人的签名信息记录在案,以备汇总、清算之用。智能卡还可用在各种事物管理、安全管理场所,如身份证明、健康记录和职工考勤、各种收费系统、宾馆服务系统等。

1.3 主要研究内容

1.3.1 身份认证机制

身份认证是实现网络安全的重要机制之一。在安全的网络通信中,涉及的通信各方必须通过某种形式的身份验证机制来证明它们的身份,验证用户的身份与所宣称的是否一致,然后才能实现对于不同用户的访问控制和记录。下面介绍几种常用的身份认证机制。

1.3.1.1 基于 DCE/Kerberos 的认证机制

基于 DCE/Kerberos 的身份认证是用户通过安全服务器上登录,获得身份的证明。当然在登录前该用户必须已经注册,同时在客户端必须运行 DCE 的客户端软件。

DCE/Kerberos 是一种被证明为非常安全的双向身份认证技术。DCE/Kerberos 的身份认证强调了客户机对服务器的认证;而其它产品,只解决了服务器对客户机的认证。以自动取款机 ATM 为例,客户必须防止来自服务端的欺骗,因为如果存在欺骗,那么客户将泄露自己的帐户信息。

1.3.1.2 基于公共密钥的认证机制

目前在 Internet 上也使用基于公共密钥的安全策略进行身份认证,具体而言,

使用符合 x. 509 的身份证明。使用这种方法必须有一个第三方的证明授权 CA 中心为客户签发身份证明。客户和服务端各自从 CA 获取证明, 并且信任该证明授权中心。在会话和通讯时首先交换身份证明, 其中包含了将各自的公钥交给对方, 然后才使用对方的公钥验证对方的数字签名、交换通讯的加密密钥等。在确定是否接受对方的身份证明时, 还需检查有关服务器, 以确认该证明是否有效 (如图)。

1.3.1.3 基于挑战/应答的认证机制

基于挑战应答 (Challenge/Response) 的身份认证机制就是每次认证时认证服务器端都给客户端发送一个不同的“挑战”字串, 客户端程序收到这个“挑战”字串后, 做出相应的“应答”。

著名的 Radius 认证机制就是采用这种方式。它的设计思路是在客户和服务端之间采用 UDP 进行交互, 使之轻型化: 采用挑战/应答方式进行认证, 避免口令字在网络上传输; 认证不定期地进行, 并且每次认证的报文不同, 防止被他人“重放”攻击, 也保证用户不会被他人冒用地址而受损。

1.3.2 访问控制技术

访问控制是网络安全防范和保护的主要策略, 它的主要任务是保证网络资源不被非法使用和访问。它是保证网络安全最重要的核心策略之一。访问控制涉及的技术也比较广, 包括入网访问控制、网络权限控制、目录级控制以及属性控制等多种手段。

1.3.2.1 入网访问控制

入网访问控制为网络访问提供了第一层访问控制。它控制哪些用户能够登录到服务器并获取网络资源, 控制准许用户入网的时间和准许他们在哪台工作站入网。用户的入网访问控制可分为三个步骤: 用户名的识别与验证、用户口令的识别与验证、用户账号的缺省限制检查。三道关卡中只要任何一关未过, 该用户便不能进入该网络。网络管理员可以控制和限制普通用户的账号使用、访问网络的时间和方式。用户账号应只有系统管理员才能建立。

1.3.2.2 权限控制

网络的权限控制是针对网络非法操作所提出的一种安全保护措施。用户和用户组被赋予一定的权限。网络控制用户和用户组可以访问哪些目录、子目录、文件和其他资源。可以指定用户对这些文件、目录、设备能够执行哪些操作。

1.3.2.3 目录级安全控制

网络应允许控制用户对目录、文件、设备的访问。用户在目录一级指定的权

限对所有文件和子目录有效,用户还可进一步指定对目录下的子目录和文件的权限。对目录和文件的访问权限一般有八种:系统管理员权限、读权限、写权限、创建权限、删除权限、修改权限、文件查找权限、访问控制权限。一个网络管理员应当为用户指定适当的访问权限,这些访问权限控制着用户对服务器的访问。八种访问权限的有效组合可以让用户有效地完成工作,同时又能有效地控制用户对服务器资源的访问,从而加强了网络和服务器的安全性。

1.3.2.4 属性安全控制

当用文件、目录和网络设备时,网络系统管理员应给文件、目录等指定访问属性。属性安全在权限安全的基础上提供更进一步的安全性。网络上的资源都应预先标出一组安全属性。用户对网络资源的访问权限对应一张访问控制表,用以表明用户对网络资源的访问能力。属性设置可以覆盖已经指定的任何受托者指派和有效权限。属性往往能控制以下几个方面的权限:向某个文件写数据、拷贝一个文件、删除目录或文件、查看目录和文件、执行文件、隐含文件、共享、系统属性等。

1.3.2.5 服务器安全控制

网络允许在服务器控制台上执行一系列操作。用户使用控制台可以装载和卸载模块,可以安装和删除软件等操作。网络服务器的安全控制包括可以设置口令锁定服务器控制台,以防止非法用户修改、删除重要信息或破坏数据;可以设定服务器登录时间限制、非法访问者检测和关闭的时间间隔。

1.3.3 活动目录技术

Windows2000 是微软公司新一代的操作系统,它是在 Windows NT4.0 操作系统的基础上开发的,集 Windows NT 技术和 Windows9X 的优点于一身,并在此基础上发展了许多新的特性和功能。如智能镜像、终端服务、分布式文件系统、磁盘定额、DNS 增强以及活动目录等等。其中最重要的特性是活动目录。

活动目录包括两方面:目录和目录相关的服务。目录是存储各种对象的一个物理上的容器,目录管理的基本对象是用户、计算机、文件以及打印机等资源。而目录服务是使目录中所有信息和资源发挥作用的服务,如用户和资源管理、基于目录的网络服务、基于网络的应用管理。

使用活动目录使得信息的安全性大大增强,同时引入基于策略的管理,使系统的管理更加明朗。活动目录具有很强的可扩展性,具有很强的可伸缩性,智能的信息复制能力。它同时与 DNS 集成紧密,与其他目录服务具有互操作性。

1.3.4 证书管理技术

CA 中心最重要的工作是证书管理,按 RFC 2510 的定义,证书管理必须满

足以下要求：

- ✓ 必须遵守 ISO 9594-8 标准和相应的修正方案；
- ✓ 必须能定期地更新密钥对而不影响其他密钥对；
- ✓ 应使管理中的保密措施对日常规章的影响最小；
- ✓ 必须允许使用不同工业标准密码算法（包括 RSA, DSA, MD5, SHA-1）；
- ✓ 必须有撤消证书的措施；
- ✓ 允许在更新密钥对的情况下也能验证证书。

根据以上分析，证书管理中可以实现以下功能：

- (1) 根 CA 的初始化，所有其他的服务都依赖根 CA 生成的根证书；
- (2) 根 CA 钥对的更新，根证书钥对只有有限的生存期，因此必须定期更新。同时帮助旧的证书持有者安全地切换到新的证书持有状态。
- (3) 证书撤消列表的生成，证书只在指定的期限内有效，根 CA 必须定期地搜集所有的失效证书并生成列表以供证书验证使用。
- (4) CA 信息请求，所有终端用户都应能通过消息请求获得 CA 的当前状态。
- (5) 证书请求，终端用户能向 CA 发出请求以获得所需的证书。
- (6) 终端初始化，终端和 CA 一样，也需要初始化，包括获取 CA 的状态信息和一个根 CA 的公钥。
- (7) 密钥对更新，当终端的钥对快到期时，它向根 CA 请求得到一个新的证书和钥对。

1.4 论文章节安排

本文的主要工作可以概括如下：分析现有身份认证和访问控制的现状及其相关问题，提出运用智能卡技术加以优化，设计 Windows2000 图形化用户交互界面，实现双重验证机制，从而使操作系统的安全性和可靠性得到提高。

全文共分为七章，各章内容安排如下：

第一章为绪论，介绍课题的背景和研究现状，智能卡技术简介。然后对本课题的主要研究内容进行介绍。

第二章：智能卡技术及其 Windows2000 中智能卡功能分析。本章将介绍 Windows2000 对智能卡技术的支持策略和方法。并介绍 Windows 智能卡子系统的体系结构以及相应的支持程序。对其智能卡功能问题进行深入分析，提出了为了适合于 Windows2000 的可行的智能卡应用领域和方向。

第三章：密码学基础 PKI 和证书。本章首先介绍公共密钥设施的相关内容与技术。接着讨论核心算法，在比较了各种算法之后，简单介绍了数字证书技术，并

阐述了数字证书的原理和作用。本章还介绍了授权机构 CA 的基本概念相关技术，并且简单分析了认证中心的功能。

第四章：身份认证和访问控制技术。本章将首先简要介绍目前已有的身份认证协议和认证机制。在分析了传统的用户身份识别方法之后，提出了基于智能卡的用户身份识别方法。最后对访问控制技术进行了一定的阐述，同时分析了 Windows2000 下的访问控制原理

第五章：基于智能卡的安全登录系统的设计。本章主要针对基于智能卡的安全登录系统进行原理分析和体系构架设计。首先介绍了 Winlogon 和 GINA 的基本概念，分析了 Winlogon 的工作原理和模型。在完成了对 Windows2000 身份认证体系以后，提出了基于智能卡的认证方案的总体设计方案。同时相应的对客户端和服务端进行详细设计，规定了各个部分需要实现的主要功能

第六章：基于智能卡的安全登录系统的设计。本章首先对基于智能卡的安全登录系统的实施方案 HiQ SecureLogon 系统进行简要介绍。然后分别说明了客户端 GINA 部分的实现和服务端 SLogonConsole 的实现。在客户端中，详细阐述了 GINA 的实现细节，包括应用函数说明，登录流程说明，以及智能卡插拔锁定和管理员身份认证的细节说明。在服务端中，详细说明了主要的类库实现。

第七章：总结与展望。本章将对全文工作进行总结，对在本文基础上的后续工作进行概述。

第二章 Windows 下的智能卡技术

当今数据网中占统治地位的技术是 IP 协议和以太网。基于这些成熟的网络技术建立存储网，是许多技术专家和厂商的心愿。随着以太网的速度提升到 1G 并向 10G 发展及 IP 技术应用的进一步深入，基于 IP 的存储网技术逐步走向成熟，以 iSCSI 协议为代表的 IP 存储协议已形成标准。本章将介绍 IP 存储网络及其代表技术，并在此基础上对目前存在的问题加以讨论，考虑到实用性的需要和相关研究的薄弱，重点对其 I/O 性能问题和特点加以分析，并介绍与分析存储网络环境中可选择的各种 I/O 性能优化技术，其中即包括网络缓存技术。

2.1 智能卡技术概述

2.1.1 支持智能卡的策略

Microsoft 将智能卡视为其公钥结构 (PKI) 支持的一个重要组件。智能卡增强了诸如客户身份验证、交互登录和安全电子邮件等仅由软件构成的解决方案。因为下列原因，智能卡是公钥证书和相关密钥的汇合点：

- (1)提供防篡改存储以保护私钥以及其他形式的个人信息。
- (2)将包括身份验证、数字签名和密钥交换在内的关系到安全性的运算与系统的其他部分隔离开。
- (3)实现了凭据以及其他私人信息在工作地点、家庭或移动用户的计算机之间的便携性。

智能卡将越来越多地与 Windows 操作系统的新发行版本实现集成。最终，现在需要密码才可以进行的任何操作将来都可以使用智能卡。

2.1.2 支持智能卡的方法

Microsoft 出于以下几点鼓励采纳和使用智能卡：

- (1)硬件互操作性-鼓励智能卡读卡器和智能卡与计算机之间实现接口的标准模型。
- (2)应用程序互操作性-提供独立于读卡器和智能卡的 API，实现应用程序对智能卡的支持。
- (3)开发人员支持-为软件开发提供熟悉的工具。
- (4)对 Windows 的全方位支持-为所有 Windows 操作系统提供智能卡支持。

2.3 Microsoft 产品中的智能卡支持

本节说明了 Windows 2000 中智能卡子系统的体系结构以及智能卡功能。

2.3.1 智能卡子系统的体系结构

智能卡子系统包括下列组件：

- (1)服务提供程序-智能卡 CSP 和 SCard COM 服务提供程序
- (2)资源管理器
- (3)设备驱动程序
- (4)读卡器驱动程序库

2.3.2 服务提供程序

所有的智能卡都必须具有至少一个服务提供程序以使基于 Windows 的应用程序能够访问基于智能卡的服务。根据卡以及发卡人类型的不同，可能会有多个服务提供程序。通常有两类服务提供程序：加密的和非加密的。

2.3.3 资源管理器

智能卡“资源管理器”是作为受信任服务在单个进程中运行的。对智能卡的所有访问请求都先通过“资源管理器”，然后路由到含有被请求卡的智能卡读卡器。因此，“资源管理器”管理并控制所有应用程序对智能卡的访问，只要智能卡插入到连接至基于 Windows 计算机的任何读卡器中。“资源管理器”为给定的应用程序提供了与被请求智能卡之间的虚拟直接连接。

“资源管理器”执行三个基本任务来管理对多个读卡器和智能卡的访问。首先，它将够识别并跟踪资源。第二，它在多个应用程序之间分配读卡器和资源。最后，它支持一些事务原语，从而实现对特定卡上的服务的访问。这很重要，因为目前的卡片是单线程设备，通常需要执行多个命令才能完成单个功能。事务控制允许在不中断的情况下执行多条命令，从而确保了中间状态信息不会被破坏。

2.3.4 设备驱动程序

特定读卡器的设备驱动程序将读卡器的功能映射到 Windows 操作系统和智能卡基础结构提供的本机服务。读卡器设备驱动程序将卡的插入和取出事件通知给“资源管理器”，并通过 T=0 或 T=1 协议提供进出卡的数据通信能力。

2.3.5 读卡器驱动程序库

开发人员可以使用 Smart Card Base Components 1.0 附带的公用驱动程序库来简化设备驱动程序的开发。该共享库支持实现智能卡和读卡器之间数据通信所必需的 ISO 7816 和公用系统函数。与过去的智能卡读卡器设备驱动程序开发方式相比这是一个重大进步,因为现在有了可供开发人员利用的标准接口。这些公用接口能够使智能卡读卡器的设备驱动程序开发以一种一致的方式进行,并且可供所有 Windows 应用程序访问,这与只有选定的一些应用程序知道如何与特定读卡器通信是截然不同的。

2.4 Windows2000 中的智能卡功能

通过增强客户身份验证和安全消息发送等仅有软件参与的解决方案,Windows 2000 中的智能卡使应用程序能够在蓬勃发展的全球数字经济中适应更多的未来机会。智能卡为应用程序开发人员提供了一种安全机制,该机制能够完善企业和消费者解决方案。

2.4.1 客户身份验证

客户身份验证涉及向服务器表明和验证客户端身份以建立安全的通信通道。诸如安全套接字层 (SSL) 或传输层安全 (TLS) 等安全协议通常是与客户端提供的受信任公钥证书一起使用的。该证书可以向服务器标明客户端身份。例如,客户端可以是运行在 Windows 上的 Microsoft Internet Explorer,服务器可以是 Internet Information Server 或其他支持 SSL/TLS 的 Web 服务器。

安全会话是通过交换密钥使用公钥身份验证,以得到一个唯一的会话密钥,然后将其用于确保数据在整个会话中的完整性和保密性而建立的。可以通过先前建立的访问控制特权,将证书映射到用户或组帐户来实现附加的身份验证。通过起到私钥材料安全存储和用于执行数字签名或数字交换操作的加密引擎的作用,智能卡增强了公钥身份验证过程。

2.4.2 公钥交互登录

过去,交互式登录意味着通过使用某种形式的凭据(例如,散列运算后的密码)将用户对网络进行身份验证的这一能力。通过使用存储在带有私钥的智能卡上的 X.509 版本 3 密钥,Windows 2000 支持公钥交互登录。用户不输入密码,而是将个人识别码 (PIN) 输入到图形身份识别和验证 (GINA),然后 PIN 将用户的身份对卡进行验证。

用户的公钥证书是从卡上通过一个安全的过程检索到的,然后经过检验被证明有效而且是来自受信任的签发人。在身份验证过程中,将基于证书中包含的公

钥将一个质询发送到智能卡。该质询验证智能卡是在相应的私钥控制下，并且可以成功地使用此私钥。

在成功地完成对私钥和公钥对的验证后，将使用证书中包含的用户身份来引用存储在 Active Directory 中的用户对象以构建令牌或将一个“通信证已获得通知”(TGT) 返回给客户端。公钥登录已经集成到了 Kerberos 版本 5 的 Microsoft 实现中，它可以与在 IETF 草案 RFC-1510 中制定的公钥扩展相兼容。

2.4.3 安全电子邮件

安全电子邮件是另一个更让人兴奋的具有公钥功能的应用程序，因为它允许用户通过保密的方式共享信息，并且让用户确信在传输过程中维护了信息的完整性。使用 Microsoft Outlook® Express 或 Microsoft Outlook，用户可以选择使用由受信任证书颁发机构签发的公钥证书来进行数字签名和对安全邮件进行解密。通过将用户的密钥发布到企业或 Internet 上的公共目录中，公司中的或 Internet 上的其他用户可以将加密的电子邮件发送给该用户，反之亦然。

智能卡增加了安全电子邮件应用程序的完整性，因为它可以将私钥存储在卡上，受到 PIN 的保护。要想攻破私钥并以其他人的名义发送签名电子邮件，用户必须获得智能卡和 PIN。

第三章 密码学基础——PKI 和证书

3.1 PKI 简介

全球经济发展正在进入信息经济时代,知识经济初见端倪。作为二十一世纪的主要经济增长方式--电子商务,将给各国和世界经济带来巨大的变革,产生深远的影响。电子商务通过大幅度降低交易成本,增加贸易机会,简化贸易流程,提高贸易效率;电子商务提高生产力,改善物流系统,并推动企业和国民经济结构的改革。对电子商务的关注和投入可以发展新兴产业,创造就业机会,推动国家和全球经济的发展。电子商务是一个新兴市场,而且是一种替代传统商务活动的新形式。它有可能彻底改变贸易活动的本质,形成一套全新的贸易活动框架。但如何保证 Internet 网上信息传输的安全,是发展电子商务的重要环节。

为解决 Internet 的安全问题,世界各国对其进行了多年的研究,初步形成了一套完整的 Internet 安全解决方案,即目前被广泛采用的 PKI(Public Key Infrastructure-公钥基础设施),PKI(公钥基础设施)技术采用证书管理公钥,通过第三方的可信任机构--认证中心 CA(Certificate Authority),把用户的公钥和用户的其它标识信息(如名称、e-mail、身份证号等)捆绑在一起,在 Internet 网上验证用户的身份。目前,通用的办法是采用建立在 PKI 基础之上的数字证书,通过把要传输的数字信息进行加密和签名,保证信息传输的机密性、真实性、完整性和不可否认性,从而保证信息的安全传输。

3.2 数字证书

数字证书是各类实体(持卡人/个人、商户/企业、网关/银行等)在网上进行信息交流及商务活动的身份证明,在电子交易的各个环节,交易的各方都需验证对方证书的有效性,从而解决相互间的信任问题。证书是一个经证书认证中心数字签名的包含公开密钥拥有者信息以及公开密钥的文件。

从证书的用途来看,数字证书可分为签名证书和加密证书。签名证书主要用对用户信息进行签名,以保证信息的不可否认性;加密证书主要用对用户传送信息进行加密,以保证信息的真实性和完整性。简单的说,数字证书是一段包含用户身份信息、用户公钥信息以及身份验证机构数字签名的数据。身份验证机构的数字签名可以确保证书信息的真实性。证书格式及证书内容遵循 X.509 标准。

数字证书的应用

现有持证人甲向持证人乙传送数字信息,为了保证信息传送的真实性、完整性和不可否认性,需要对要传送的信息进行数字加密和数字签名,其传送过程如下:

- (1) 甲准备好要传送的数字信息(明文)。

- (2) 甲对数字信息进行哈希 (hash) 运算, 得到一个信息摘要
- (3) 甲用自己的私钥 (SK) 对信息摘要进行加密得到甲的数字签名, 并将其附在数字信息上。
- (4) 甲随机产生一个加密密钥 (DES 密钥), 并用此密钥对要发送的信息进行加密, 形成密文。
- (5) 甲用乙的公钥 (PK) 对刚才随机产生的加密密钥进行加密, 将加密的 DES 密钥连同密文一起传送给乙。
- (6) 乙收到甲传送过来的密文和加过密的 DES 密钥, 先用自己的私钥 (SK) 对加密的 DES 密钥进行解密, 得到 DES 密钥。
- (7) 乙然用 DES 密钥对收到的密文进行解密, 得到明文的数字信息, 然后将 DES 密钥抛弃 (即 DES 密钥作废)。
- (8) 乙用甲的公钥 (PK) 对甲的数字签名进行解密, 得到信息摘要。
- (9) 乙用相同的 hash 算法对收到的明文再进行一次 hash 运算, 得到一个新的信息摘要。
- (10) 乙将收到的信息摘要和新产生的信息摘要进行比较, 如果一致, 说明收到的信息没有被修改过。

3.3 PKI 核心 – 认证中心

3.3.1 认证中心 CA 简介

为保证网上数字信息的传输安全, 除了在通信传输中采用更强的加密算法等措施之外, 必须建立一种信任及信任验证机制, 即参加电子商务的各方必须有一个可以被验证的标识, 这就是数字证书。数字证书是各实体(持卡人/个人、商户/企业、网关/银行等)在网上信息交流及商务交易活动中的身份证明。该数字证书具有唯一性。它将实体的公开密钥同实体本身联系在一起, 为实现这一目的, 必须使数字证书符合 X.509 国际标准, 同时数字证书的来源必须是可靠的。这就意味着应有一个网上各方都信任的机构, 专门负责数字证书的发放和管理, 确保网上信息的安全, 这个机构就是 CA 认证机构。各级 CA 认证机构的存在组成了整个电子商务的信任链。如果 CA 机构不安全或发放的数字证书不具有权威性、公正性和可信赖性, 电子商务就根本无从谈起。

数字证书认证中心 (Certificate Authority, CA) 是整个网上电子交易安全的关键环节。它主要负责产生、分配并管理所有参与网上交易的实体所需的身份认证数字证书。每一份数字证书都与上一级的数字签名证书相关联, 最终通过安全链追溯到一个已知的并被广泛认为是安全、权威、足以信赖的机构-根认证中心 (根

CA)。

电子交易的各方都必须拥有合法的身份,即由数字证书认证中心机构(CA)签发的数字证书,在交易的各个环节,交易的各方都需检验对方数字证书的有效性,从而解决了用户信任问题。CA涉及到电子交易中各交易方的身份信息、严格的加密技术和认证程序。

数字证书认证解决了网上交易和结算中的安全问题,其中包括建立电子商务各主体之间的信任关系,即建立安全认证体系(CA);选择安全标准(如SET、SSL);采用高强度的加、解密技术。其中安全认证体系的建立是关键,它决定了网上交易和结算能否安全进行,因此,数字证书认证中心机构的建立对电子商务的开展具有非常重要的意义。

认证中心(CA),是电子商务体系中的核心环节,是电子交易中信赖的基础。它通过自身的注册审核体系,检查核实进行证书申请的用户身份和各项相关信息,使网上交易的用户属性客观真实性与证书的真实性一致。认证中心作为权威的、可信赖的、公正的第三方机构,专门负责发放并管理所有参与网上交易的实体所需的数字证书。

3.3.2 CA/RA 简介

开放网络上的电子商务要求为信息安全提供有效的、可靠的保护机制。这些机制必须提供机密性、身份验证特性(使交易的每一方都可以确认其它各方的身份)、不可否认性(交易的各方不可否认它们的参与)。这就需要依靠一个可靠的第三方机构验证,而认证中心(CA: Certification Authority)专门提供这种服务。

证书机制是目前被广泛采用的一种安全机制,使用证书机制的前提是建立CA(Certification Authority --认证中心)以及配套的RA(Registration Authority --注册审批机构)系统。

CA中心,又称为数字证书认证中心,作为电子商务交易中受信任的第三方,专门解决公钥体系中公钥的合法性问题。CA中心为每个使用公开密钥的用户发放一个数字证书,数字证书的作用是证明证书中列出的用户名称与证书中列出的公开密钥相对应。CA中心的数字签名使得攻击者不能伪造和篡改数字证书。

在数字证书认证的过程中,证书认证中心(CA)作为权威的、公正的、可信赖的第三方,其作用是至关重要的。认证中心就是一个负责发放和管理数字证书的权威机构。同样CA允许管理员撤销发放的数字证书,在证书废止列表(CRL)中添加新项并周期性地发布这一数字签名的CRL。

RA(Registration Authority),数字证书注册审批机构。RA系统是CA的证书发放、管理的延伸。它负责证书申请者的信息录入、审核以及证书发放等工作;同时,对发放的证书完成相应的管理功能。发放的数字证书可以存放IC卡、硬盘或软盘等介质中。RA系统是整个CA中心得以正常运营不可缺少的一部分。

3.3.3 认证中心的功能

概括地说，认证中心（CA）的功能有：证书发放、证书更新、证书撤销和证书验证。CA 的核心功能就是发放和管理数字证书，具体描述如下：

- 接收验证最终用户数字证书的申请。
- 确定是否接受最终用户数字证书的申请-证书的审批。
- 向申请者颁发、拒绝颁发数字证书-证书的发放。
- 接收、处理最终用户的数字证书更新请求-证书的更新。
- 接收最终用户数字证书的查询、撤销。
- 产生和发布证书废止列表（CRL）。
- 数字证书的归档。
- 密钥归档。
- 历史数据归档。

认证中心为了实现其功能，主要由以下三部分组成：

- 注册服务器：通过 Web Server 建立的站点，可为客户提供每日 24 小时的服务。因此客户可在自己方便的时候在网上提出证书申请和填写相应的证书申请表，免去了排队等候等烦恼。
- 证书申请受理和审核机构：负责证书的申请和审核。它的主要功能是接受客户证书申请并进行审核。
- 认证中心服务器：是数字证书生成、发放的运行实体，同时提供发放证书的管理、证书废止列表（CRL）的生成和处理等服务。

第四章 身份认证和访问控制技术

4.1 身份认证协议

4.1.1 Kerberos 认证体制

Kerberos 是为 TCP/IP 网络设计的可信的第三方鉴别协议。网络上的 Kerberos 服务者起着可信仲裁者的作用。Kerberos 可提供安全的网络鉴别, 允许个人访问网络中不同的机器。Kerberos 基于对称密码学(采用的是 DES, 但也可用其他算法替代), 它与网络上的每个实体分别共享一个不同的秘密密钥, 是否知道该秘密密钥即是身份的证明。

Kerberos 最初是麻省理工学院(MIT)为 Athena 项目而开发的, Kerberos 基于 Needham-Schroeder 的可信第三方协议。在 Kerberos 模型中, 具有安装在网络上的实体; 即客户机和服务器, 客户机可以是用户, 也可以是处理事务所需的独立的软件程序: 下载文件, 发送消息, 访问数据库, 访问打印机, 获取管理特权等。

Kerberos 工作原理

Kerberos 协议很简明, 客户从 Kerberos 请求一张票据作为票据许可服务 (Ticket-Granting Service, TGS), 该票据用用户的秘密密钥加密后发送给用户。为了使用特定的服务器, 客户需要从 TGS 中请求一张票据。假定所有事情均按序进行, TGS 将票据发回给客户, 客户将此票据呈示给服务器和鉴别器, 如果客户的身份没有问题, 服务器便会让客户访问该服务。

Kerberos 使用两类凭证: 票据 (Ticket) 和鉴别码 (Authenticator)。票据用于秘密地向服务器发送持有票据用户的身份识别。票据中还包括有一些信息, 服务器能够用这些信息来确认使用票据的客户与发给票据的客户是同一个客户。鉴别码是另外一个凭证, 与票据一道发送。Kerberos 票据的格式如下:

对单个的服务器和客户而言, 票据很有用, 它包括客户名, 服务器名, 网络地址, 时间标记和会话密钥。这些信息用服务器的秘密密钥加密, 客户一旦获得该票据, 他便可以多次用它来访问服务器, 直到票据过期。客户无法解密票据 (他不知道服务器的秘密密钥), 但他可以以其加密的形式呈递给服务器。票据在网络上传送时, 任何在网上窃听的人都无法阅读或者修改它。Kerberos 鉴别码的格式如下:

客户在每次需要使用服务器上的服务时, 都需要产生一个鉴别码。该鉴别码包括用户名, 时间标记和一个可选的附加会话密钥, 他们用服务器与客户共享的会话密钥加密。与票据不同的是, 鉴别码只能使用一次。尽管如此, 由于客户可以根据需要产生鉴别码 (他知道共享的秘密密钥), 这是没有问题的。

鉴别码可以达到两个目的：首先，它包括一些会话密钥加密的明文，这表明鉴别码的发送者也知道密钥。重要的是，加密的明文包括时间标记，即使记录下票据和鉴别码的窃听者在两天后也无法重放他们。

4.1.2 SSL 协议

随着计算机网络技术向整个经济社会各层次延伸，整个社会表现对 Internet、Intranet、Extranet 等使用的更大的依赖性。随着企业间信息交互的不断增加，任何一种网络应用和增值服务的使用程度将取决于所使用网络的信息安全有无保障，网络安全已成为现代计算机网络应用的最大障碍，也是急需解决的难题之一。由于 Web 上有时要传输重要或敏感的数据，因此 Netscape 公司在推出 Web 浏览器首版的同时，提出了安全通信协议 SSL(SecureSocketLayer)，目前已有 2.0 和 3.0 版本。SSL 采用公开密钥技术。其目标是保证两个应用间通信的保密性和可靠性，可在服务器和客户机两端同时实现支持。目前，利用公开密钥技术的 SSL 协议，并已成为 Internet 上保密通讯的工业标准。现行 Web 浏览器普遍将 HTTP 和 SSL 相结合，从而实现安全通信。

安全套接层协议(SSL)是在 Internet 基础上提供的一种保证私密性的安全协议。它能使客户/服务器应用之间的通信不被攻击者窃听，并且始终对服务器进行认证，还可选择对客户进行认证。SSL 协议要求建立在可靠的传输层协议(例如：TCP)之上。SSL 协议的优势在于它是与应用层协议独立无关的。高层的应用层协议(例如：HTTP，FTP，TELNET)能透明地建立在 SSL 协议之上。SSL 协议在应用层协议通信之前就已经完成加密算法、通信密钥的协商以及服务器的认证。在此之后应用层协议所传送的数据都会被加密，从而保证通信的私密性。

通过以上叙述，SSL 协议提供的安全信道有以下三个特性：

秘密性：因为在握手协议定义了会话密钥后，所有的消息都被加密。

确认性：因为尽管会话的客户端认证是可选的，但是服务器端始终是被认证的。

可靠性：因为传送的消息包括消息完整性检齐(使用 MAC)。

4.1.3 CA 证书

CA 是证书的签发机构，它在 PKI 中扮演可信任的代理商角色，是 PKI 的核心。众所周知，构建密码服务系统的核心内容是如何实现密钥管理，公钥体制涉及到一对密钥，即私钥和公钥，私钥只由持有者秘密掌握，无须在网上传送，而公钥是公开的，需要在网上传送，故公钥体制的密钥管理主要是公钥的管理问题，目前较好的解决方案是引进证书(certificate)机制。

证书是公开密钥体制的一种密钥管理媒介。它是一种权威性的电子文档，形同网络计算环境中的一种身份证，用于证明某一主体（如人、服务器等）的身份

以及其公开密钥的合法性。在使用公钥体制的网络环境中,必须向公钥的使用者证明公钥的真实合法性。因此,在公钥体制环境中,必须有一个可信的机构来对任何一个主体的公钥进行公证,证明主体的身份以及他与公钥的匹配关系。CA 正是这样的机构,它的职责归纳起来有:签发证书;管理证书;确保整个签证过程的安全性和签名私钥的安全性;确保证书主体标识的唯一性;发布并维护 CRL(证书撤销列表);对整个证书签发过程做日志记录;向申请人发通知。

CA 的数字签名保证了证书的合法性利权威性,因此 CA 必须管理好自己的私钥,必须确保其高度的机密性,防止他方伪造证书。CA 的公钥应在网上公开,以方便用户使用。用户 A 可通过两种方式获取用户 B 的证书和公钥,一种是由 B 将证书随同发送的正文信息一起传送给 A,另一种是所有的证书集中存放于一个证书库中,用户 A 可从该地点取得 B 的证书。

由于密码算法是公开的,信息交换的安全性就完全基于密钥的安全保护上。在当今的信息交换过程中,信息交换双方之间不一定有直接的信赖关系,必须通过共同的认证机构 CA(Certificate Authority)作为中心,来实现信赖的传递。即当用户 A 与用户 B 需要进行安全的通信时,双方都必须得到对方的认证。CA 中心作为信息交换服务的证贴中心,是 PKI(PublicKeyInfrastructure)体系的核心。它为用户的公开密钥签发公钥证书、发放证书、管理证书,并提供一系列密钥生命周期内的管理服务。它将客体的公钥与客体的名称和其他属性关联起来,为用户间电子身份的认证,提供了良好的安全保障。是一个具有权威性、可信赖性和公证性的第三方机构。它的存在,是信息交换存在的基础。CA 是公开密钥体制的一种密钥管理媒介。在使用公钥体制的网络环境中,必须向公钥的使用者证明公钥的真实合法性。

CA 的职责归纳起来有:

- 1)验证并标识证书申请者的身份:
- 2)确保 CA 用于签名证书的非对称密钥的质量:
- 3)确保整个签证过程的安全性,确保签名私钥的安全性;
- 4)证书材料信息(包括公钥证书序列号、CA 标识等)的管理
- 5)确定并验证证书的有效期限:
- 6)确保证书主体标识的唯一性,防止重名
- 7)发布并维护作废证书表;
- 8)对整个证书签发过程做日志记录:
- 9)向申请人发通知。

其中最为重要的是 CA 自己的一对密钥的管理,它必须确保其高度的机密性,防止他方伪造证书。CA 的公钥在网上公开,整个网络系统必须保证完整性。

4.1.4 X.509 数字证书

X.509 是 ISO 和 CCITT/ITU-T 的 X.500 标准系列的一部分,在 PKI 概念由小的、封闭式网络的实验环境变到大的、开放式分布环境的过程中,在很多方面 X.509 标准起了无可比拟的作用,当实体在很大程度上相互不了解的情况下,证书使公钥技术变得可行。于是,将 PKI 应用于跨国公司或上百万的 Internet 用户时,必须要有一个可用的证书格式。为在多种工具和应用软件中实现互操作,证书的格式应加以标准化并被广为接受。以下是 X.509 扮演的角色:这个规范定义并标准化了一个通用的、灵活的证书格式。它被广泛采用的事实也证明了其技术适应于多种环境,作为国际标准的有效性是表现在被众多的生产商实现产品时采用它。X.509 的实用性来源于它为证书版本 3 利版本 2 中证书撤销列表所定义的强有力的扩展机制。无论怎样定义及放置于证书或证书撤销列表中的扩展,这一机制都是很通用的。此外,一个重要的标志是指示了认证者是否必须了解并在认证者是否必须了解并在认证过程中校验这些扩展。于是,证书和证书撤销列表内容可按照意愿被裁减来适用于特定的环境,或在其它特定的环境中不限制它的可用性。

字段的说明:

- 1 版本号——标示证书的版本;
- 2 序列号——由证书颁发者分配的本证书的唯一标识符;
- 3 签 名——签名算法标识符,用于说明本证书所用的数字签名算法;
- 4 颁发者——证书颁发者的可识别名(DN),这是必须说明的;
- 5 有效期——证书有效的时间段;
- 6 主 体——证书拥有者的可识别名(此字段必须非空,除非使用了其他的名形式):
- 7 主体公钥信息——主体的公钥(以及算法标识符);
- 8 颁发者的唯一标识符——证书颁发者的唯一标识符,
- 9 主体唯一标示符——证书拥有者的唯一标示符,可选项,实际中很少使用
- 10 扩展——可选的标准和专用扩展

尽管 X.509 是一国际标准,已经达到了标准化的最高水平,被认为是非常稳定的,但在某些方面 X.509 仍处于发展之中。实际操作中发现的任何问题已经(且将继续)通过正式的缺陷报告和解决途径在标准中予以声明。某些情况对标准的修正也会包含进去来校正文档或提供附加细节。

4.2 常用的用户身份识别方法

4.2.1 传统的用户身份识别方法

用户身份认证的最简单方法就是口令。系统事先保存每个用户的二元组信息(ID_x , PW_x)。进入系统时用户 x 输入 ID_x 和 PW_x , 系统根据保存的用户信息和用户输入的信息相比较, 从而判断用户身份的合法性。很明显, 这种身份认证方法操作十分简单, 但同时又最不安全因为其安全性仅仅基于用户口令的保密性, 而用户口令一般较短而且容易猜测, 因此这种方法不能抵御口令猜测攻击; 另外, 口令明文传输使得系统攻击者很容易通过搭线窃听方法获取用户口令; 最后, 由于系统保存的是口令的明文形式。一方面需要系统管理员是可信赖的, 另一方面, 一旦攻击者能访问口令表, 整个系统的安全性就受到了威胁。口令方案对重传攻击也是毫无抵抗能力的。

一个改进的方案是口令的加密传输。由于传输的是用户口令的密文形式, 系统仅保存用户口令的密文, 因而窃听者不易获得用户的真实口令, 但是这种方案仍然受到口令猜测的攻击, 外系统入侵者还可以采用离线方式对口令密文实施字典攻击。

4.2.2 基于智能卡的用户身份识别方法

一般来说, 用户身份认证可通过三种基本方式或其组合方式来实现:

用户所知道的某个秘密信息, 例如用户知道自己的口令;

用户所持有的某个秘密信息 (硬件), 用户必须持有合法的随身携带的物理介质, 例如智能卡中存储用户的个人化参数, 访问系统资源时必须要有智能卡。

用户所具有的某些生物学特征, 如指纹, 声音, DNA 图案, 视网膜扫描等等, 但是这种方案一般造价较高, 适用于保密程度很高的场合。基于智能卡的用户身份认证机制结合了 1 2, 用户信息(ID_x , PW_x)存在智能卡中, AS 中存入某个事先由用户选择的随机数。用户访问系统资源时, 用户输入(ID_x , PW_x)。系统首先判断智能卡的合法性, 然后由智能卡鉴别出用户身份, 若用户身份合法, 再将智能卡中的随机数送给 AS 作进一步认证。这种方案基于智能卡的物理安全性, 即不易伪造和不能直接读取数据。没有管理中心发放的智能卡, 则不能访问系统资源, 即使智能卡丢失, 入侵者仍然需要猜测用户口令。

一次口令机制

最安全的身份验证机制是采用一次口令机制, 即每次用户登录系统时口令互不相同。主要有两种实现方式: 第一种采用请求/应答方式 (Challenge/Response), 用户登录时系统随机提示一条信息, 用户根据这一信息连同其个人化数据共同产生一个口令字, 用户输入这个口令字, 完成一次登录过程, 或者用户对这一条信

息实施数字签名发送给 AS 进行鉴别；第二种方法采用时钟同步机制，即根据这个同步时钟信息连同其个人化数据共同产生一个口令字。这两种方案均需要 AS 端也产生与用户端相同的口令字（或检验用户签名）用于验证用户身份。

4.3 访问控制简介

4.3.1 访问控制的定义

访问是使信息在主体和对象间流动的一种交互方式。

主体是指主动的实体，该实体造成了信息的流动和系统状态的改变，主体通常包括人、进程和设备。

对象是指包含或接受信息的被动实体。对对象的访问意味着对其中所包含信息的访问。对象通常包括记录、块、页、段、文件、目录、目录树和程序以及位、字节、字、字段、处理器、显示器、键盘、时钟、打印机和网络节点。

访问控制决定了谁能够访问系统，能访问系统的何种资源以及如何使用这些资源。适当的访问控制能够阻止未经允许的用户有意或无意地获取数据。访问控制的手段包括用户识别代码、口令、登录控制、资源授权（例如用户配置文件、资源配置文件和控制列表）、授权核查、日志和审计。

访问控制是信息安全保障机制的核心内容，它是实现数据保密性和完整性机制的主要手段。访问控制是为了限制访问主体（或称为发起者，是一个主动的实体；如用户、进程、服务等），对访问客体（需要保护的资源）的访问权限，从而使计算机系统在合法范围内使用；访问控制机制决定用户及代表一定用户利益的程序能做什么，及做到什么程度。

访问控制的两个重要过程：

- 1、通过"鉴别（authentication）"来检验主体的合法身份
- 2、通过"授权（authorization）"来限制用户对资源的访问级别

访问包括读取数据，更改数据，运行程序，发起连接等。

4.3.2 访问控制分类

因实现的基本理念不同，访问控制可分为以下两种：

强制访问控制（Mandatory access control）

自主访问控制（Discretionary access control）

强制访问控制（MAC）用来保护系统确定的对象，对此对象用户不能进行更改。也就是说，系统独立于用户行为强制执行访问控制，用户不能改变他们的

安全级别或对象的安全属性。这样的访问控制规则通常对数据和用户按照安全等级划分标签，访问控制机制通过比较安全标签来确定的授予还是拒绝用户对资源的访问。强制访问控制进行了很强的等级划分，所以经常用于军事用途。

在强制访问控制系统中，所有主体（用户，进程）和客体（文件，数据）都被分配了安全标签，安全标签标识一个安全等级。访问控制执行时对主体和客体的安全级别进行比较。

自主访问控制机制允许对象的属主来制定针对该对象的保护策略。通常 DAC 通过授权列表（或访问控制列表）来限定哪些主体针对哪些客体可以执行什么操作。如此将可以非常灵活地对策略进行调整。由于其易用性与可扩展性，自主访问控制机制经常被用于商业系统。

自主访问控制中，用户可以针对被保护对象制定自己的保护策略。

每个主体拥有一个用户名并属于一个组或具有一个角色

每个客体都拥有一个限定主体对其访问权限的访问控制列表（ACL）

每次访问发生时都会基于访问控制列表检查用户标志以实现对其访问权限的控制

在商业环境中，你会经常遇到自主访问控制机制，由于它易于扩展和理解。大多数系统仅基于自主访问控制机制来实现访问控制，如主流操作系统(Windows NT Server, UNIX 系统)，防火墙（ACLs）等。

强制访问控制和自主访问控制有时会结合使用。例如，系统可能首先执行强制访问控制来检查用户是否有权访问一个文件组（这种保护是强制的，也就是说：这些策略不能被用户更改），然后再针对该组中的各个文件制定相关的访问控制列表（自主访问控制策略）。

4.3.2 Windows2000 访问控制原理

Windows2000 采用面向对象的概念来提供一种强大、灵活的访问控制能力，访问控制由两个实体管理：与每个进程相关联的访问令牌和与每个对象相关联的安全描述符。

图四 a 显示了访问令牌的通用结构，包括以下参数：

- 安全 ID (SID)：在主机中唯一的确定一个用户，通常对应于用户的登录名。
- 组 SID (GSID)：关于该用户属于哪些组的列表。一组用户的 ID 号基于访问控制的目的被标识为一个组。对一个对象的访问可以基于组 SID、个人 SID 或它们的组合来定义。
- 特权：该用户可以调用的一组对安全性敏感的系统服务。大多数用户都没有特权。

- 默认的所有者：如果该进程创建了一个对象，这个域将决定该对象的所有者。
- 默认 ACL：这是使用于保护用户创建的所有对象的初始表。

图四 b 显示了安全描述符的一般结构，它包括以下参数：

- 标记：定义了一个安全描述符的类型和内容。
- 所有者：该对象的所有者可以在这个安全描述符上执行任何操作。
- 系统访问控制表（SACL）：确定该对象上的哪些操作可以产生审核信息。应用程序必须在它的访问令牌中具有相应的特权，才可以读或写任何对象的 SACL。
- 自由访问控制表（DACL）：确定哪些用户和组可以为哪些操作访问该对象。它由一组访问控制项（ACE）组成。

安全 ID (SID)
组 SID
特权
默认所有者
默认 ACL

(a) 访问令牌

标记
所有者
系统访问控制表 (SACL)
自由访问控制表 (DACL)

(b) 安全描述符

图 4-1 Windows2000 安全结构

下面我们来看看 Windows2000 的访问控制方案。

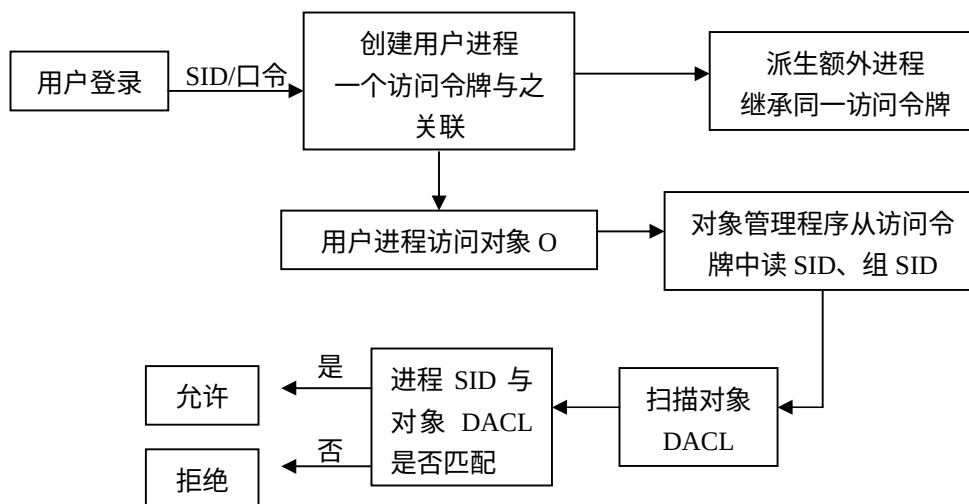


图 4-2 Windows2000 的访问控制过程图

由于访问控制表是 Windows2000 访问控制机制的核心，我们来详细分析一下它的结构（图六）。每个表由整个表的表头和许多访问控制项组成。每一项定义一个个人 SID 或组 SID，访问掩码定义了该 SID 被授予的权限。当进程试图访问一个对象时，系统中该对象的管理程序从访问令牌中读取 SID 和组 SID，然后扫描该对象的 DACL。如果发现有一项匹配，也就是说，如果找到了一个 ACE，它的 SID 与访问令牌中的一个 SID 匹配，那么该进程就具有了该 ACE 的访问掩码所确定的访问权限。



图 4-3 Windows2000 的访问控制列表

第五章 基于智能卡的安全登录系统的设计

5.1 Winlogon 和 GINA 简介

Winlogon 是 Windows 2000/NT 操作系统提供交互式登录支持的组件。Winlogon 有三个组成部分：可执行文件 winlogon.exe，提供图形界面认证功能的动态库 Gina Dll (Graphical Identification and Authentication)，以及一些网络服务提供动态库 Network Provider Dll。模型如下图所示：

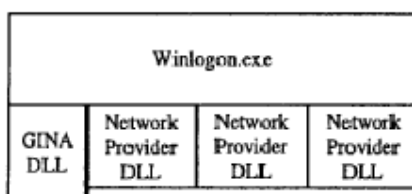


图 1 Winlogon 模型

各个部分的主要功能如下：

Winlogon.exe	除了加载交互式登录所需的其他两个组件之外，Winlogon.exe 还要处理设计到与验证策略无关的用户界面的操作。这些操作包括创建可用的桌面，向操作系统注册一个安全维护序列 SAS (Secure Attention Sequence)，维护工作站状态和实现超时处理。另外，Winlogon 还要向 GINA 发送事件通知消息，并提供可供 GINA 调用的各种接口函数，如查询，桌面操作和消息框处理等。
GINA 的动态连接库	这个模块按照验证策略执行用户交互。GINA 是在系统引导过程的早期由 Winlogon 加载的一个可替换的动态连接库，它提供了 Winlogon 用户标识和验证用户的输出函数，并且必须遵守保证系统安全的一系列完整性规则。因为交互式登录模式允许用其它的 GINA 模块替换这个动态连接库，所以它支持可定制的用户识别与身份认证。
网络提供程序的动态连接库	Winlogon 还可以加在一个或多个网络提供程序动态连接库，以提供通过标准协议到 Novell 等其他类型网络的辅助身份验证。

由上可以看出，GINA 是 Winlogon 调用的一个可以替换的 DLL 模块。Winlogon.exe 处理一些下层导出的接口函数，而认证策略是在 Gina Dll 中是独立设计的。在 Windows NT/2000 中交互式的登录支持是由 WinLogon 调用 GINA DLL 实现的，GINA DLL 提供了一个交互式的界面为用户登录提供认证请求。在系统启动时，Gina Dll 被 winlogon.exe 装载。WinLogon 会和 GINA DLL 进行交

互，缺省是 MSGINA.DLL(在 System32 目录下)。Microsoft 提供了一个默认的 Gina Dll——Winnt\system32\msgina.dll，提供了标准的用户名、密码认证模式。通过替换 Gina.dll 可以实现用其他的认证方式来代替 Windows 默认的用户名密码登录。用户可以设计自己的 Gina Dll，以提供其他如智能卡、视网膜、指纹或其他一些认证机制。

当 Winlogon 初始化的时候，它的首要任务之一就是要在系统注册一个 SAS。该 SAS 提供了到操作系统的可信路径，可以保证其它应用程序不能通过这个案件序列来试图捕获用户的口令。默认的 SAS 是 CTRL+ALT+DEL。

WinLogon 初始化时会创建 3 个桌面：

(1)、winlogon 桌面：一旦接收到 SAS，Winlogon 就切换到 Winlogon 桌面进行用户身份验证。这个桌面为用户名，域名和口令等识别信息提供了安全对话框。

(2)、应用程序桌面：无论何时用户进行登录都会创建这个桌面，并且在登录会话期间都是可用的。应用程序桌面也叫用户桌面，是已经登录用户进行所有操作的地方。应用程序桌面是受到保护的，只有系统和已登录用才有权对它进行访问。

(3)、屏幕保护桌面：屏幕保护界面。在屏幕保护程序执行期间就会激活这个桌面。系统在任何时候都可以访问这个桌面。而交互式登录会话则只能在当前已有用户登录时才可以访问它。

GINA 所执行的验证操作是因状态而异的。GINA 根据 Winlogon 的当前状态来决定需要什么操作，每种状态都可以从 GINA 调用许多可能的操作。Winlogon 可以维护下列三种状态：

已注销状态。已注销状态发生在没有交互时登录会话期间，Winlogon 提示用户输入识别验证信息，如口令和智能卡。一经被 GINA 成功验证，Winlogon 就从以注销状态改变到已登录状态。

已登录状态。已登录状态允许用户访问应用程序桌面，并执行任何所需的任务。可以从这一状态转换到其他两种状态（已注销状态和已锁定工作站状态）。用户可以关闭应用程序并注销，在这种情况下，Winlogon 就会终止所有还连接到用户登录会话的进程，并返回到已注销状态。用户还可以把作业挂起并锁定工作站以俾后用，在这种情况下，Winlogon 就会转换到已锁定工作站状态。

已锁定工作站状态。这个状态提供了一个安全桌面，要求要么功过用户身份验证切换到已登录状态，要么通过管理员身份验证切换到已注销状态。用户通过提供原来的登录证书，就可以解锁工作站从而激活应用程序桌面。而管理员则可以通过提供管理账户证书来终止应用进程，并返回到已注销状态。

5.2 Windows2000 身份认证技术分析

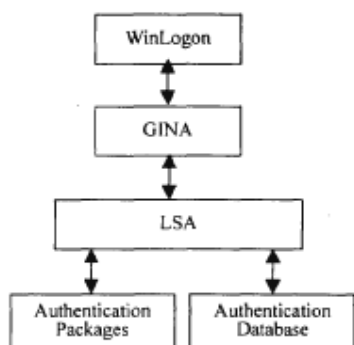
作为网络系统的一部分，操作系统的安全有着举足轻重的地位。因此，正

如其它安全产品一样，Windows2000 操作系统必须在每个实体访问资源之前验证其身份，并确定其是否有访问该资源的权限，这一过程称为身份验证和访问控制。

在 Windows2000 中，处理用户身份严整的模块被称作认证授权机构（Authentication Authority）。认证授权机构随着用户的登录情况不同而有所差别；如果登录的是本地机器，则是本地机器自身的安全授权机构 LSA（Local Security Authority）；否则，如果是登录到域中，则由域控制器（DC）中的 LSA 执行身份验证过程。为了能够确认用户的身份，安全授权机构必须保存用户的一个信任状（Credential：包括用户名，密码，访问令牌等信息），这些数据通常存放在验证数据库中。

Windows2000 系统构建于四个基本的登录类型之上：本地登录（或称交互式登录），网络登录（或称非交互式登录），批登录和服务登录。批登录一般用户任务调度处理；而服务登录则用于所有操作系统提供的服务。这四种登录类型在体系结构上有一些差别，下面着重讨论一下交互式身份验证体系结构。

下图表示了交互式身份验证过程。



一个交互式身份验证过程开始于安全注意序列 SAS（Secure Attention Sequence）被激活的任何时候。当 SAS 被激活的时候，Windows 登录处理程序 Winlogon 调用 GINA 模块。Winlogon 是 windows2000 的核心组件，并由该组件提供用户身份验证时的交互处理。GINA 则负责显示用户信息输入接口（UI），获取用户信任状以及将这些信息提交给本地安全授权机构（LSA）处理。

LSA 也是 windows2000 的内核组件，并且充当安全授权机构，它与安全数据库及身份验证软件包交互信息，并且处理用户的验证请求。因此 LSA 决定一个用户是否有权登录的主要依据来源就是身份验证软件包和安全数据库。

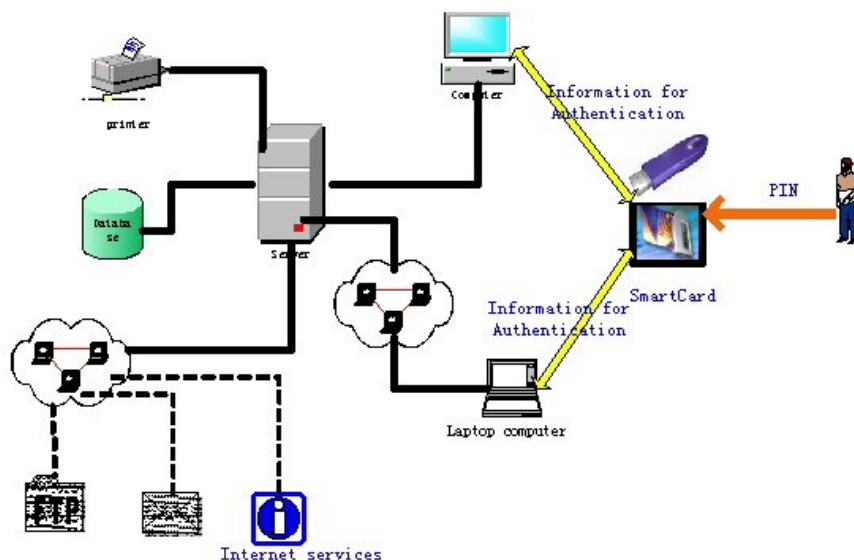
身份验证软件包是根据不同的验证协议实现的软件模块。Windows2000 已经实现了两种身份验证模块：MSV1_0 和 Kerberos。但是 Kerberos 身份验证软件包目前还不能处理工作站和成员服务器的本地登录请求；同时 Kerberos 需要配置密钥分发中心（KDC）服务，该服务只在 Windows2000 域控制器中实现了。验证数据库用于存储验证过程中所需的用户信任状信息。在 windows2000 工作站中，用户信任状信息存储在 SAM 数据库中；在 Windows2000 域控制器中，用户信任状信息存储在活动目录中（Active Directory）。对于前者，用户帐号即为本

地账号, 后者则为域用户帐号。

5.3 系统整体设计

本方案所提出的使用智能卡进行交互式登录的过程与传统的基于口令的登录过程有相似的地方。

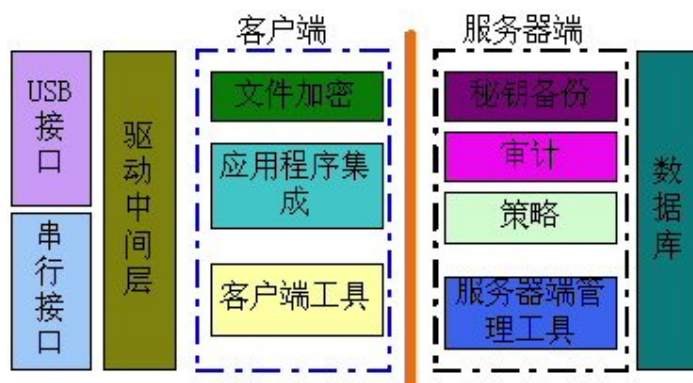
系统的网络结构图如下：



简单的流程可以说明如下：用户将智能卡插入 USB 口就可以启动登录的一系列操作, 这会产生一个 SAS, 相当于键入了 CTRL+ALT+DEL。一旦接收到 SAS, 客户端应用程序首先判断智能卡是否是由指定厂商生产的, 明确类别以后就切换到 Winlogon 桌面, 调出 GINA, 显示一个对话框要求输入智能卡的 PIN。用户输入 PIN 后, 若 PIN 正确, GINA 就从智能卡的特定区域解密出用户的所有帐号信息, 用户选择其中的一个, 请求进行登录。值得注意的是, 在发送登录请求到域服务器之前, LSA 先向本地 SAM 数据库询问用户账户的详情以及匹配的密钥。由于我们是采用的域服务器的验证方式, 本地没有相应的 windows 账户, SAM 无法找到匹配的帐户信息, LSA 就去调用 Netlogon, 通过 Netlogon 预先建立的安全通道, 把用户的登录信息送到域服务器上去验证, 如果域服务器在 AD(Active Directory)找到了账户信息, 它就向 MSV1_0 验证程序包返回用户的 SID (The Security Identifier) 和用户所在组的 SID, 并再次通过 Netlogon 把验证结果返回到 LSA。如果域服务器没有找到账户信息, 验证失败结果也要返回到 LSA。客户端程序从 LSA 中获得验证结果, 并把结果返回给用户, 同时对智能卡进行相应的操作, 如锁定智能卡等。

为了将智能卡技术应用在 Windows2000 登录系统, 需要定制 GINA, 将智能卡登录模块嵌入到其中, 完成其中的身份验证。

系统框架图如下：



5.4 客户端的设计

客户端登录程序 SLogon 是基于 Windows 的 GINA 对自定义的系统登录流程的支持而开发的，GINA 原理在前文已经详细讲述。客户端登录程序 SLogon 是和服务器端的 SLogonConsole 紧密地联系在一起的，SLogonConsole 对智能卡进行配置，SLogon 负责验证智能卡口令，从而正确地读取帐户信息，然后送入到 Windows 的用户验证接口。SLogon 提供的主要功能包括：USB 智能卡识别，智能卡 PIN 验证，一卡多身份以及智能卡插拔锁定与解锁等。

①USB 智能卡识别

要想在客户端正确使用 USB 智能卡，必须先客户端安装 USB 智能卡的驱动程序。这样客户端能正确地在本地注册表写入该厂商提供的 USB 智能卡的 GUID。完成安装 SLogon 程序之后，系统自动重新启动。SLogon 屏蔽掉 windows 默认的用户名-密码方式登录，强制用户必须使用特定厂商提供的 USB 智能卡进行登录。当用户插入 USB 智能卡时，SLogon 自动进行智能卡识别检查，如果所用的智能卡不是特定厂商生产的，或者插入的是其他 USB 设备，则系统就会出现错误提示。如果所用智能卡满足要求，系统提示需要输入 PIN 码进行验证登陆。

②智能卡 PIN 验证

对于智能卡的使用用户来说，PIN 是标示用户身份的标志之一。正确的用户 PIN 和实际的智能卡硬件结合在一起能够比较精确的标示一个用户的真实身份。用户输入的 PIN 通过 GINA 送入到智能卡中，智能卡调用特定的验证程序在智能卡内部进行验证。验证通过以后，就可以取得保存在当前智能卡中的所有 Windows 登录账号和密码信息。如果用户输入口令错误，多次验证失败以后，智能卡将被锁定，从而需要管理员解锁以后才能够恢复正常的的使用。这样的锁定机制有效的防止了用户进行重复攻击的可能。另外，智能卡本身具有一定的加密功能，所有的用户帐号和密码信息都是加密过的，即使智能卡丢失，其他用户也没有办法读取智能卡内的用户信息。

③一卡多身份

所谓一卡多身份,指的是一张智能卡中储存了多个用户帐号和密码对,每一对用户帐号和密码标示了一个用户的特定身份。一个特定的用户,他既可以是该域的域管理员,具有较高的系统管理权限,也可以是普通的 USER 或者 GUEST,只有较低的使用权限。在支持智能卡本地登录的方式下,该用户也可以是本地(Local Machine)的管理员或者普通用户。如图 2 所示不同的用户身份,通过智能卡硬件以及 PIN,和真实的用户形成了多对一的映射。一卡多身份的技术,一方面有效地解决了账号的管理问题,使得同一个用户无需再记住多个不同的登陆账号信息,另一方面有效的控制了登录用户的权限。

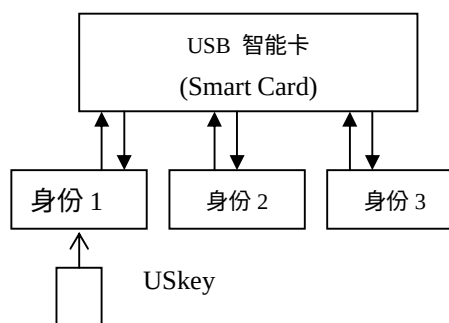


图 5

④智能卡插拔锁定与解锁

智能卡是用户身份的象征,只有具有智能卡的用户才能够使用特定的计算机,当用户因特殊原因需要离开计算机时,用户需要拔出智能卡,此时 SLogon 客户端程序将会监测到由 USB 口发出的设备移出(DEVICEREMOVAL)消息,该消息是广播消息,但是附带了设备变更时间发起者智能卡的 GUID,因此系统能够识别出是智能卡插拔还是其他的 USB 设备的插拔。根据这个消息,智能卡拔出以后,系统进入锁定状态。同时记录下锁定人的账号信息以及锁定时间等相关信息。当用户回到计算机旁,重新插入智能卡时,系统同样能够监测到类似的设备到达(DEVICEARRIVAL)消息,提示用户输入智能卡的口令 PIN。如果口令验证成功,系统将会验证解锁人的身份。如果验证成功,系统将解除锁定,否则继续保持锁定状态。多次尝试解除锁定失败将会导致智能卡锁死。

智能卡插拔锁定与解锁技术,大大的提高了用户使用的方便性,同时对安全性也有一定程度的保障。

5.5 服务器端的设计

①服务器端保存/管理用户信息

首先,管理中心(即服务器端)先建立一个用户信息数据库,里面存储有用户证书,机器名(能唯一标识该机器的标识符,如可以是 IP 地址,MAC 地址,同时这也作为登录该机器的用户名),机器密码(用于登录机器)等信息。其中机器名与密码应该使用用户的公钥加密存储。当用户信息更改时,要及时更新该数据库,如用户证书的更新和撤销等。

这里面有一点要加以说明,机器名和机器密码是登录机器的有效用户名-密码,而用户的证书是表示该用户身份的唯一合法标识,数字证书里有对该用户的详细情况的说明,有了它,用户可以在规定的局域网内部以规定的身份(由管理

员来分配，如可以是 power user 或 guest 等）登录任何一台机器。

②生成有效的 USB Key

当有新用户提出申请时，管理员根据他的需求为他生成一张数字证书，还可以在数据库中配置他可以登录局域网中的哪些资源，同时把这张证书以及对应的私钥写入一个全新的 USB Key 中，生成一张普通登录卡。私钥存储在智能卡中特殊的文件分区里，不能向外读，以保证私密性，但可以使用该私钥，利用智能卡 CSP 在卡内部对数据进行加密或签名。用户使用这张卡就登录到规定的机器上去了。

③接受客户机注册

当客户端第一次使用客户端软件登录时，会通过网络向管理中心注册。客户端读出 Key 中的证书，同时在本地创建本地账户名（即机器名，如本地的 IP 地址）和密码（随机创建一个比较健壮的密码），经过私钥加密一起发给管理中心。管理中心接到后，经过验证，如果证书合法，认为此用户是合法用户，并且发现数据库中没有此机器名，就会认为这台机器是第一次被登录，需要进行注册，就把此机器名和的机器密码加入数据库。然后管理中心向客户端发回确认信息，客户端收到后，认为注册成功。这个过程对使用 Key 的用户来说是透明的。在用户看来，他插入 Key 后，只要求他输入 PIN 码，其他一切操作，都由计算机自动完成，最后只返回给他一个结果：注册是否成功。如果卡中的证书是非法的，即服务器数据库中没有记录，则注册失败，用户不能安装客户端软件。

由客户端生成本地账户和密码并发送给服务器来确认而不是由服务器来直接分配，可以使整个系统有较好的扩展性，比如局域网中新添加了一台机器，可以直接在客户端登录，而不必修改添加服务器上的数据。

④认证用户

当客户端已经注册之后，其他用户使用各自的 Key 再次登录此机器就不再需要注册了。与注册类似，用户将卡插入后，客户端读出用户证书，并连同机器名一并发送到服务器端请求验证。服务器会发现此机器已经过注册，于是验证用户身份成功后，会读出数据库中的机器名和机器密码，经过用户的公钥加密后发回给客户端。客户端收到机器名和密码，经过解密，就可以登录了。

⑤对卡的其他操作

当注销一个用户，或更新用户信息时，不仅要对管理中心的数据库进行更新，也要同时注销或者更新 USB Key。注销之后，将不能再使用该 Key 进行登录。

⑥日志记录

在普通用户登录时，其登录的情况会上传到管理中心，管理中心会生成相应的日志记录，以供管理员进行审计。

第六章 基于智能卡的安全登录系统的实现

6.1 HiQ SecureLogon 简介

今天,无论是企业的内部办公系统或是企业间的商务协作系统,都是建立在现代计算机网络的基础之上的。而所有基于计算机网络的应用都必然受到网络与信息安全问题的困扰。有的企业为了文件和信息的安全,采用物理隔断的方式强行将内网与外网断开,内网也根据不同的产品或型号将其划分为不同的子网,各个子网之间也互不相联,甚至采用将一切可能转移数据的设备包括软驱拆除,禁用 USB 接口,并将机箱锁死的方式,来阻塞一切可能的泄密渠道。这样做可以提高企业的信息安全等级,但同时,也给企业的信息流通带来了极大的不便,对企业的生产效率影响很大。

激烈的市场竞争环境要求企业实现办公业务的电子化、自动化和网络化,共享企业各单位办公业务信息资源,使企业行政管理、应急指挥和快速反应的能力进一步提高,高效率、高质量地为各业务部门宏观管理、科学决策服务。

慧勤网络与信息安全系统为企业在 Internet 上开展各种商务应用提供了一个安全、可靠的保障。

慧勤 HiQ-SLogon 系统包括慧勤安全控制台 SmartCard SLogon Console, 慧勤智能卡安全登录子系统和慧勤智能卡安全加密子系统。该系统利用智能卡实现了基于智能卡硬件的安全系统登录、office 系列软件的封装加密以及智能卡的管理控制台。它为用户实现准确的身份认证和用户授权,以及文档的安全保护提供了有力的保障。

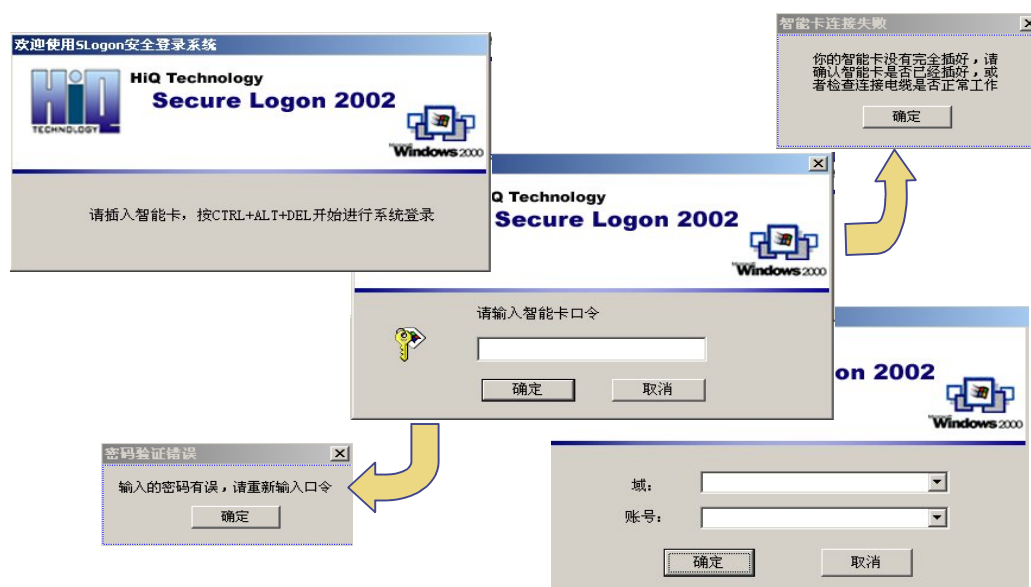


图 SLogon 界面

6.2 客户端 GINA 部分实现说明

6.2.1 函数说明

开发自定义的 Gina Dll，必须实现并导出与 winlogon.exe 交互的 18 个标准函数接口。

这 18 个标准函数接口的名称和功能如下：

Function	Description
WlxActivateUserShell	激活用户外壳程序
WlxDisplayLockedNotice	允许 gina.dll 显示锁定信息
WlxDisplaySASNotice	当没有用户登录的时候，winlogon 调用此函数
WlxDisplayStatusMessage	当要显示一个状态消息时，winlogon 调用此函数
WlxGetConsoleSwitchCredentials	winlogon 调用此函数，读取当前登录用户的信任书并透明地传输给一个目标会话
WlxGetStatusMessage	Winlogon 调用这个函数获得当前的状态消息
WlxInitialize	初始化一个 windows 工作站的 gina.dll
WlxIsLockOk	确认工作站是不是允许锁定
WlxIslogoffOk	确认工作站是不是允许注销
WlxLoggedOnSAS	当前已经有用户登录，且工作站没有被锁定，且 winlogon 接收到一个 sas 时，winlogon 就会调用这个函数
WlxLoggedOutSAS	当前没有用户登录，且 winlogon 接收到一个 sas 时，winlogon 就会调用这个函数
WlxLogoff	通知 gina.dll 已经有一个注销操作被请求
WlxNegotiate	告知 gina.dll 当前 winlogon 可以使用的版本
WlxNetworkProviderLoad	在 winlogon 加载一个网络供应者以获得确认授权和身份验证信息之后，winlogon 调用此函数
WlxRemoveStatusMessage	Winlogon 调用此函数，告诉 gina.dll 停止显示状态消息

WlxScreensaverNotify	允许 gina.dll 和屏幕保护操作进行交互
WlxShutdown	在关机之前, winlogon 调用此函数, 允许 gina 执行任何的关机任务, 比如从读写器中拔出智能卡
WlxStartApplication	当在用户语义下系统需要启动一个应用进程时, winlogon 调用此函数
WlxWkstaLockedSAS	当工作站被锁定, 且 winlogon 接收到一个 sas 时, winlogon 调用此函数

其中 WlxNegotiate 是 winlogon.exe 调用的第一个接口函数。在这个函数里, 指明了 winlogon 的版本, 在 HiQ 安全登陆系统中, 所用的版本是 WLX_VERSION_1_3, 其函数接口的组织形式如下表:

```
typedef struct __win32_DISPATCH_VERSION_1_3 {
    PWLX_USE_CTRL_ALT_DEL WlxUseCtrlAltDel;
    PWLX_SET_CONTEXT_POINTER WlxSetContextPointer;
    PWLX_SAS_NOTIFY WlxSasNotify;
    PWLX_SET_TIMEOUT WlxSetTimeout;
    PWLX_ASSIGN_SHELL_PROTECTION WlxAssignShellProtection;
    PWLX_MESSAGE_BOX WlxMessageBox;
    PWLX_DIALOG_BOX WlxDialogBox;
    PWLX_DIALOG_BOX_PARAM WlxDialogBoxParam;
    PWLX_DIALOG_BOX_INDIRECT WlxDialogBoxIndirect;
    PWLX_DIALOG_BOX_INDIRECT_PARAM WlxDialogBoxIndirectParam;
    PWLX_SWITCH_DESKTOP_TO_USER WlxSwitchDesktopToUser;
    PWLX_SWITCH_DESKTOP_TO_WINLOGON
WlxSwitchDesktopToWinlogon;
    PWLX_CHANGE_PASSWORD_NOTIFY WlxChangePasswordNotify;
    PWLX_GET_SOURCE_DESKTOP WlxGetSourceDesktop;
    PWLX_SET_RETURN_DESKTOP WlxSetReturnDesktop;
    PWLX_CREATE_USER_DESKTOP WlxCreateUserDesktop;
    PWLX_CHANGE_PASSWORD_NOTIFY_EX
```

```

WlxChangePasswordNotifyEx;

    PWLX_CLOSE_USER_DESKTOP WlxCloseUserDesktop;

    PWLX_SET_OPTION WlxSetOption;

    PWLX_GET_OPTION WlxGetOption;

    PWLX_WIN31_MIGRATE WlxWin31Migrate;

    PWLX_QUERY_CLIENT_CREDENTIALS WlxQueryClientCredentials;

    PWLX_QUERY_IC_CREDENTIALS WlxQueryInetConnectorCredentials;

    PWLX_DISCONNECT WlxDisconnect;

    PWLX_QUERY_TERMINAL_SERVICES_DATA
WlxQueryTerminalServicesData;

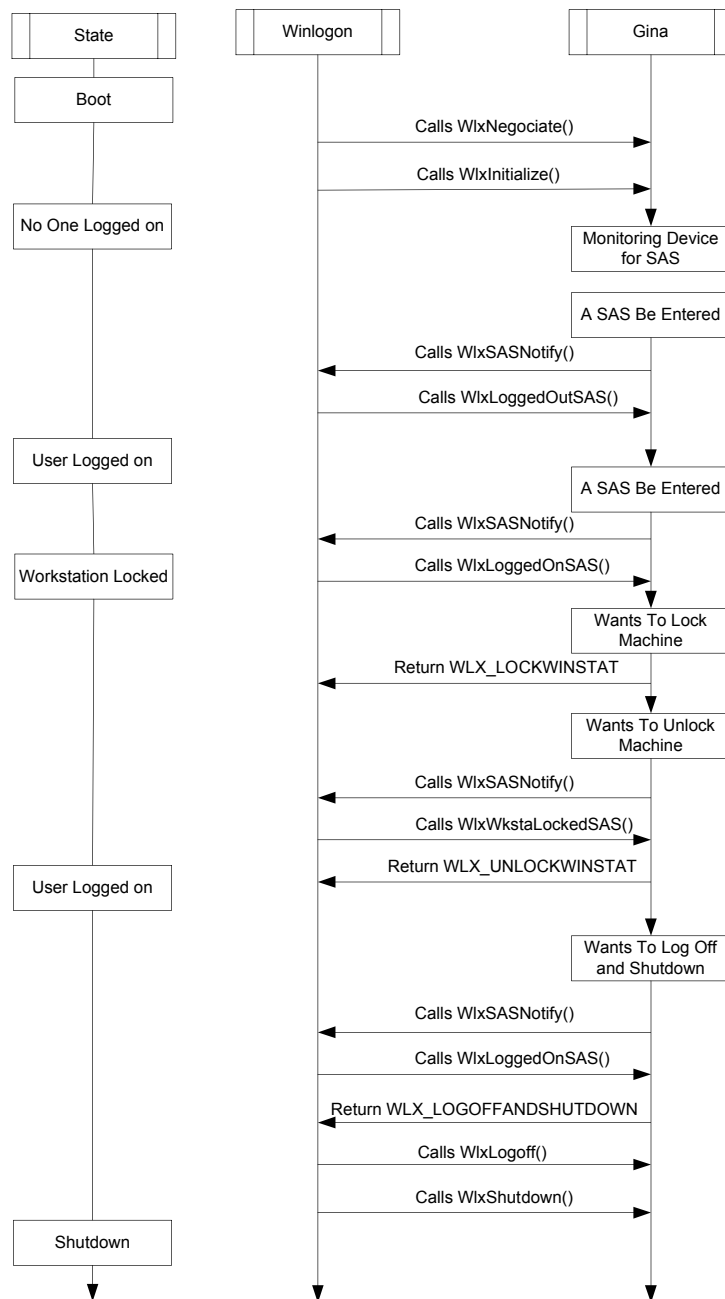
    } WLX_DISPATCH_VERSION_1_3;
    
```

在 WlxNegotiate 进行必要的版本判断之后，调用的是 WlxInitialize，主要完成 winlogon.exe 特定版本的函数分派表向 Gina Dll 的传递。还要说明的是 WlxLoggedOnSAS 函数，这个函数主要的功能是，当 winlogon 在登录成功状态下，接收到 SAS 事件，于是调用这个函数进行 SAS 事件的识别以及进行各事件的相应处理。

除了以上 18 个 gina 必须要实现的 winlogon 的接口函数以外，gina 还可以调用如下的一些函数，这些函数的名称和功能如下：

Function	Called By Gina
WlxAssignShellProtection	为一新的已登陆用户外壳请求保护
WlxChangePasswordNotify	通知系统用户已经修改了密码, 可用于通知所有网络提供者
WlxChangePasswordNotifyEx	通知系统用户已经修改了密码, 可用于通知一个或所有网络提供者
WlxCloseUserDesktop	关闭用户桌面
WlxCreateUserDesktop	创建用户桌面
WlxDialogBox	从一个对话框模板资源创建一个模态对话框

WlxDialogBoxIndirect	从内存中的一个对话框模板资源创建一个模态对话框
WlxDialogBoxIndirectParam	初始化对话框控件, 从内存中的一个对话框模板资源创建一个模态对话框
WlxDialogBoxParam	初始化对话框控件, 从一个对话框模板资源创建一个模态对话框
WlxDisconnect	取消与最后服务网络会话的连接
WlxGetOption	返回一个特定选项的当前值
WlxGetSourceDesktop	在 winlogon 切换到 winlogon 桌面之前, 决定需要激活的桌面的名称和句柄
WlxMessageBox	通知 winlogon 一个 sas 事件
WlxQueryClientCredentials	查询一个从 winlogon 临时会话传输到另一个 winlogon 目的会话的信用书
WlxQueryInetConnectorCredentials	查询一个正在使用 Internet 连接许可的远端用户的信用书
WlxQueryTerminalServicesData	查询最后服务用户的配置信息
WlxSasNotify	在关机之前, winlogon 调用此函数, 允许 gina 执行任何的关机任务, 比如从读写器中拔出智能卡
WlxSetContextPointer	指明 winlogon 传递的语义指针, 这个指针将做为所有 gina 函数的第一个参数
WlxSetOption	指明一个特定的选项的值
WlxSetReturnDesktop	当前的 sas 事件处理完成以后, 指明 winlogon 将要转向的桌面
WlxSetTimeout	改变一个对话框的 time-out
WlxSwitchDesktopToUser	切换到用户进程桌面
WlxSwitchDesktopToWinlogon	切换到 winlogon 桌面
WlxWin31Migrate	完成用户创建
WlxUseCtrlAltDel	提示 winlogon 使用标准的 Ctrl+Alt+Del 组合键作为 sas



WlxInitialize：Winlogon 调用一次该函数，主要是做一些初始化工作，包括获得提供的函数集的指针，为它们之间通信的全局变量分配内存、初始化。为了实现智能卡登录，在这里注册智能卡的相关信息。

WlxDisplaySASNotice：该函数的唯一功能就是显示欢迎窗口，并且监督是否有自己定义的 SAS（安全提示码序列）出现。如果出现，则要通知有个登录请求发出。这里监视智能卡用户是否有按下 Ctrl+Alt+Del 三键的登录请求。

WlxLoggedOutSAS：GINA 用这个函数来显示对话框收集用户信息，并且调用进行验证。如果用户正确输入智能卡口令，则采用智能卡进行身份验证，通过

以后允许登录。如果通过验证则在登录用户后关闭智能卡，以便进入系统后其他程序使用。

WlxActivateUserShell：成功登录后 Winlogon 将调用此函数，用来激活用户的 Shell 进程。

WlxLoggedOnSAS：此时用户已经登录，当 Winlogon 收到一个 SAS 后调用此函数。显示的界面可以让用户执行锁定计算机、注销、重新启动、关闭计算机，更改密码或启动任务管理等操作。

WlxDisplayLockedNotice：当工作站被锁定后，Winlogon 调用此函数来显示锁定信息，如锁定者、锁定时间等。此函数显示的对话框和 WlxDisplaySASNotice 显示的对话框类似，能处理 WLX_WM_SAS 消息。这里就需要再次开放智能卡。

WlxWkstaLockedSAS：工作站处于锁定状态，Winlogon 收到一个 SAS 时将调用此函数，根据返回值可以解除工作站锁定、注销当前已登录用户或继续保持工作站锁定。

WlxIsLockOk：Winlogon 在锁定工作站之前调用此函数。用来设置一些选项，如将屏幕保护标记为安全。

WlxIsLogoffOk：当用户试图注销当前用户的时候，Winlogon 调用此函数来决定是否允许注销当前用户。

WlxLogoff：Winlogon 调用此函数通知 GINA 注销当前用户。

WlxShutdown：Winlogon 在关闭计算机之前调用此函数，以便能执行一些关闭动作。如关闭智能卡。

以 WlxLoggedOnSAS 为例：

任何 SAS 序列都由 GINA 监控,具体表现为 GINA 调用 Winlogon 的函数 WlxSasNotify()指示当前消息已经进入了 SAS 序列，然后 WlxSasNotify()再将这消息通过调用 GINA 的函数 WlxloggedOnSAs 进行处理。

WlxloggedOnSAs 原型如下：

```
Int WINAPI WlxLoggedOnSAS (
    PVOID      pWlxContext,
    DWORD      dwSasType,
    PVOID      pReserved)
```

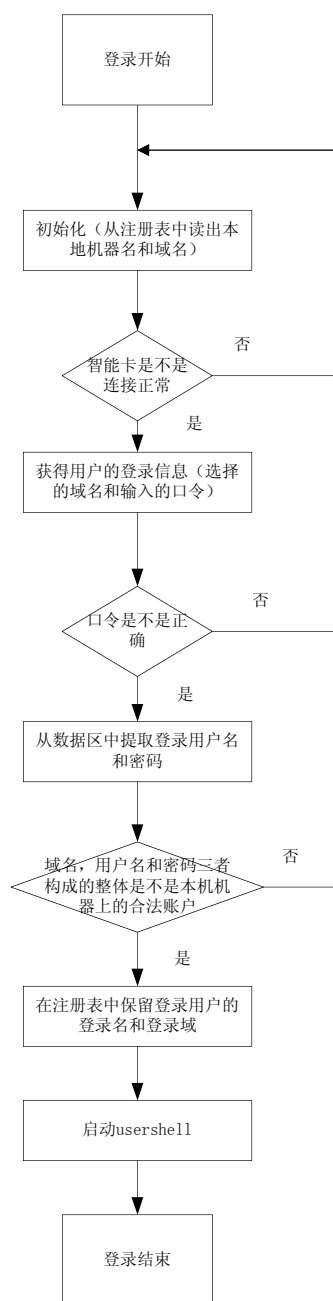
pWlxContext 是在系统启动时，Winlogon 调用 GINA 的 WlxInitialize 进行初始化后,返回的上下文指针；pReserved 是保留字，dwSasType 则是表明该消息在 SAS 中的类型,该类型定义在 WINWLX.H 中,较为重要的有：

WLXSASTYPECTRLALTDDEL 表明 CTRLALTDDEL 三键触发，

WLXSASTYPESCRNSVRTIMEOUT 表明触发屏幕保护程序等。其返回信息诸多，

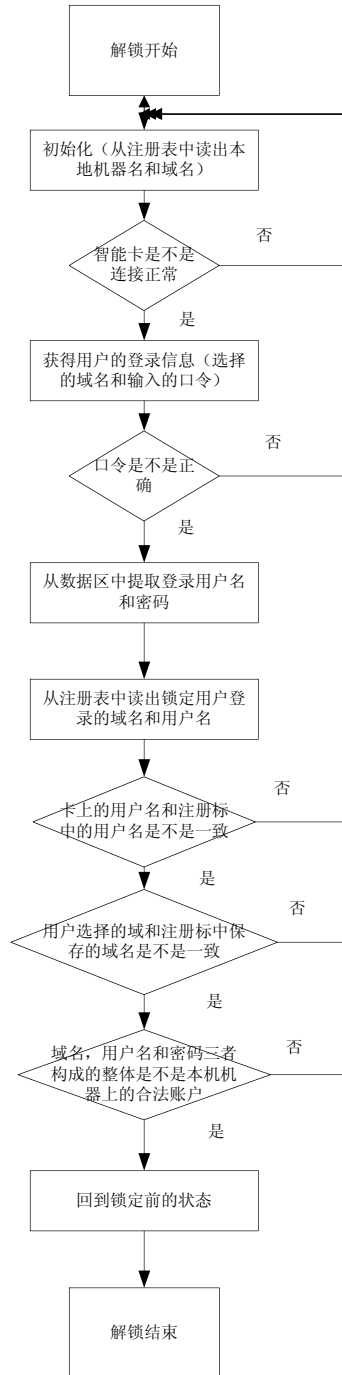
具体参阅 MSDN。

下图为登录流程的具体实现。



6.2.4 解锁流程说明

解锁流程和登录流程有着类似的地方，其中从用户获取解锁智能卡口令和从用户获取登录智能卡口令模块只存在着较小的差异。具体的解锁流程如下图所示：



6.2.5 字符串处理

由于 GINA 必须使用 SDK 来编写, 在所有操作中传递的参数必须是 UNICODE 格式, 否则函数调用不成功。在 UNICODE 的转化过程中, 可以使用 MultiByteToWideChar 和 WideCharToMultiByte 两个函数来实现普通字符串与 UNICODE 之间的转化。为了更加清楚地了解 windows 下关于 UNICODE 格式的

用户名或者口令的字符串信息，在 SLogon 中，我们特意中重写了这两个函数。其中 StringFromCharToWChar 实现了 MultiByteToWideChar 的功能。我们可以看出 UNICODE 下的用户名或者口令信息是包含了字符串结束符的，其中每一个字符占两个机器字节 sizeof(WCHAR)。

```
PWSTR StringFromCharToWChar(char* pStringInChar, int int_LengthOfStringInChar)
{
    PWSTR    New;
    DWORD    cb;
    int i;
    cb = (int_LengthOfStringInChar + 1)*sizeof(WCHAR);
    New = LocalAlloc(LMEM_FIXED, cb);
    ZeroMemory(New,cb);
    if (New)
    {
        for (i=0; i<int_LengthOfStringInChar; i++)
            memcpy(New+i,pStringInChar+i,1);
    }
    return(New);
}
```

6.2.6 智能卡检测窗口和插拔锁定

对于智能卡的拔下和插上操作，Windows 会发出系统消息 WM_DEVICECHANGE，可以通过这个系统消息获得智能卡的状态。由于 GINA 是一个 DLL，而且是由系统调用的模块，所以在 GINA 内无法进行直接的消息处理，系统通过在新的线程当中建立隐藏的非模态对话框，实现对系统消息的获得，对 WlxSASNotify 函数的调用等操作。为了能够识别智能卡的类型并且检测到相应的智能卡插拔消息，本方案中特别设置了一个特定的检测窗口 HiQ_SLogonNotify。在 HiQ_SLogonNotify 完成了以下几个内容。

1. 注册当前 USB 智能卡的 GUID

在 windows2000 系统中，充斥着大量的组件对象。每个组件对象可能又有大量的接口。为了保证这些接口彼此不会冲突，Microsoft 规定用 GUID 来标识组件对象和接口。GUID 是 Globally Unique Identifier 的缩写。意为全局唯一标识符。GUID 可以标识组件对象的类，这时候 GUID 也称为 CLSID(Class Identifier 的缩写)。GUID 也可以标识组件对象的接口，这时候 GUID 也称为 IID(Interface Identifier 的缩写)。

在 windows2000 中，智能卡可以通过与接口的全局唯一标识 (GUID) 相关联来注册对接口支持。智能卡与接口之间的这种绑定是在智能卡首次进入系统

时，特别是首次安装服务提供程序时实现的。在将智能卡引入系统后，应用程序可以搜索基于特定接口或 GUID 的智能卡。

因此，我们在安装应用程序 SLogon 之前，一定要先安装好智能卡的驱动程序。如果智能卡的驱动程序正确安装，那么系统的注册表中将会写有 WatchData 公司的智能卡的 GUID 信息，这样我们就可以读到相应的信息。

为了识别该类型的智能卡，首先在 HiQ_SLogonNotify 要通过程序来注册该类别智能卡的 GUID，其相关的程序段如下：

```
//注册智能卡的 GUID
HDEVNOTIFY HIQUSBNotificationHandle;
DEV_BROADCAST_DEVICEINTERFACE dbch;
dbch.dbcc_size = sizeof(dbch);
dbch.dbcc_devicetype = DBT_DEVTYP_DEVICEINTERFACE;
dbch.dbcc_classguid = USBCard_GUID;
dbch.dbcc_name[0] = '\0';
HIQUSBNotificationHandle = RegisterDeviceNotification(hWnd, &dbch,
DEVICE_NOTIFY_WINDOW_HANDLE);
```

该类型智能卡的 GUID 为{2fba0441-e808-11d5-84ab-00000050bcaa}

2. 分析 WM_DEVICECHANGE 消息

WM_DEVICECHANGE 消息是 windows 消息之中的一个重要组成部分，它主要用于硬件设备的消息处理。任何设备的硬件改动和操作都会在操作系统中广播 WM_DEVICECHANGE 消息。该消息的 LParam 参数中，包含了发出该消息的设备的信息，也就是我们上面所说的 GUID 信息，该消息的 WParam 参数中，包含了设备的操作改动信息，比如设备到达 DBT_DEVICEARRIVAL，设备移除 DBT_DEVICEREMOVECOMPLETE 等。

针对不同的硬件改动，我们有不同的消息响应方法。具体的处理方法可以参见以下程序段：

```
case WM_DEVICECHANGE:
//判断 SLogonConsole 程序是否在运行
hWnd_SLogonConsole = FindWindowEx(hWnd_TopDesk,NULL,NULL,"SLogonConsole");
if (hWnd_SLogonConsole != NULL)
    bln_IsSLogonConsoleOn = TRUE;
else
    bln_IsSLogonConsoleOn = FALSE;
    if (!bln_IsSLogonConsoleOn)
    {
```

```

//判断系统的 WM_DEVICECHANGE 是不是由智能卡发出的
pdbch = (PDEV_BROADCAST_DEVICEINTERFACE)lParam;
if(pdbch!=NULL&&pdbch->dbcc_devicetype==DBT_DEVTYP_DEVICEINTER
FACE)
{
switch (wParam)
{
//如果智能卡被拔出
case DBT_DEVICEREMOVECOMPLETE:
Sleep(50);
//去掉拔出异常的对话框
hwnd_TopDesk = GetDesktopWindow();
hwnd_Removal = FindWindowEx(hwnd_TopDesk,NULL,"#32770",
"不安全的设备删除");
if (hwnd_Removal != NULL)
result=SendMessage(hwnd_Removal,WM_CLOSE,0,0);
//锁定计算机
LockWorkStation();
break;
case DBT_DEVICEARRIVAL:
break;
default:;
}
}
break;

```

3. 锁定计算机

从以上的程序段可以看出，如果智能卡拔除，那么操作系统应该进入锁定状态。调用 API 函数 LockWorkStation(); 操作系统会自动调用 Winlogon 发出一个 SAS，我们自定义的 GINA 在收到 SAS 以后，将首先去查询当前用户的使用状态。如果这个在用户已经登录状态下，系统自动进入锁定状态。

6.2.7 管理员身份检测和权限分配

管理员的身份检测是身份认证的一个重要部分。本系统中 IsUserAdmin 函数较好地实现了这样的功能。其中智能卡账号的管理员是和 Windows2000 域管理员集成在一起的。AllocateAndInitializeSid 查询的就是系统域管理员的 SID。函数的具体实现如下：

```

BOOL IsUserAdmin(void)
{

```

```
int i;
BOOL bln_Result;
SID_IDENTIFIER_AUTHORITY NtAuthority = SECURITY_NT_AUTHORITY;
PSID AdministratorsGroup;
PMiniAccount    pMini;
HANDLE hTempUertoken;
//初始化
bln_Result = AllocateAndInitializeSid(
    &NtAuthority,
    2,
    SECURITY_BUILTIN_DOMAIN_RID,
    DOMAIN_ALIAS_RID_ADMINS,
    0, 0, 0, 0, 0, 0,
    &AdministratorsGroup);

//初始化
pMini = LocalAlloc(LMEM_FIXED, sizeof(MiniAccount));
pMini->pszUsername = LocalAlloc(LMEM_FIXED, 17*2);
pMini->pszPassword = LocalAlloc(LMEM_FIXED, 17*2);
pMini->pszDomain    = DupString(pszCurrentDomain);
//在卡中遍历账号
if(bln_Result)
{
    for (i=0;i<RECORD_NUMBER;i++)
    {
        if(DataFromUnlockCard[i][0]==0x00)
        {
            wcscpy(pMini->pszUsername,&DataFromUnlockCard[i][2]);
            wcscpy(pMini->pszPassword,&DataFromUnlockCard[i][19]);
            if(LogonUser(
                pMini->pszUsername,
                pMini->pszDomain,
                pMini->pszPassword,
                LOGON32_LOGON_NETWORK,
                LOGON32_PROVIDER_DEFAULT,
                &hTempUertoken))
            {
                //模拟用户的令牌
                ImpersonateLoggedOnUser(hTempUertoken);
                //检察管理员权限
                if
                (!CheckTokenMembership(hTempUertoken,AdministratorsGroup,&bln_Result))
                {
                    bln_Result = FALSE;
                }
            }
        }
    }
}
```

```
        }
        else
        {
            if(bln_Result==TRUE)
                break;
        }
    }
}

}
//释放
FreeSid(AdministratorsGroup);
}
return(bln_Result);
}
```

6.2.8 GINA 安装

我们自定义开发的 Gina Dll 文件名为 HiQSLogonGina.dll。将该文件放到以下路径：Winnt\system32。并修改注册表，如下：

Key Name: \HKEY_LOCAL_MACHINE\Software\Microsoft\Windows
NT\CurrentVersion\ Winlogon

Value Name: GinaDLL

Value Type: [REG_SZ]

Value: HiQSLogonGina.dll

重新启动计算机 HiQSLogonGina.dll 即投入使用。

6.3 服务器端 SLogonConsole 部分实现说明

密钥管理是本系统安全方案的的重要部分之一。密钥管理包括密钥的产生、分配、备份，恢复等。

在我们的安全系统中，密钥的产生是在主控制台由管理员统一产生，然后保存在智能卡硬件设备中，其中密钥的产生采用随机数的方式，生成 16 位的密钥。密钥的分发是随着智能卡硬件设备一起提供给用户的，避免了传统的密钥的分发过程中需要考虑的密钥的被窃取，泄漏。因此，密钥管理将侧重于密钥的备份以及密钥的恢复两个部分。

密钥的备份： 即时文件加密系统考虑到效率的因素，采用的是对称加密算法，密钥在主控制台上由管理员发行智能卡的时候产生，一方面密钥写入到智能

卡内用作分发给用户的途径，另一方面密钥保存在域控制器上的数据库中。为了保证密钥的机密性，保存到数据库中的密钥经过了一层加密保护，用户即使能打开数据库，仍然不能够获得密钥信息。只有通过智能卡管理工具，并掌握了外部认证密钥才能够进行密钥的导出工作。这样即使数据库文件被外人盗走，也因为没有做够的解密信息而无法破译密钥的信息。图 7-2 表示了密钥备份中所采取的保密措施：

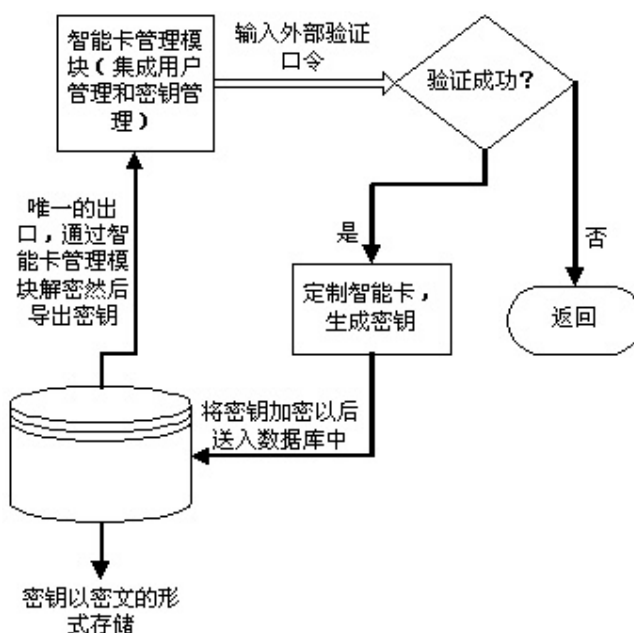


图 7-2

密钥的恢复：当用户的智能卡丢失导致内部存储的密钥的丢失，发卡者有责任为用户恢复其密钥信息，使得其可以重新登录系统以及解密已经加密的文件，避免因密钥的丢失而给用户带来较大的损失。但是允许智能卡内部密钥的导出在为用户考虑了一系列避免用户信息损失的同时，也带来了另外安全方面的隐患，如果智能卡内的信息能被轻易的导出，那么对于用户而言加密的信息相当于毫无秘密而言，因此需要制定一套较为完善的密钥恢复方案来保护用户的密钥信息。将管理员权限分散，使得一个人不能拥有对数据库内信息的控制权，必须由多个密钥管理的授权者共同来控制密钥的输出。目前较为流行的解决方案为群签名技术，但是群签名的实现较为复杂，大致需要以下的几个方面：

- (1) 创建：一个用以产生群公钥和私钥的多项式时间概率算法。
- (2) 加入：一个用户和群管理员之间的使用成为群成员的交互式协议。执行该协议可产生群成员的私钥和成员证书，并使群管理员得到群成员的私密的成员管理钥。
- (3) 签名：一个概率算法，当输入一个消息和一个群成员的私钥后，输出对消

息的签名。

(4) 验证：一个在输入对消息的签名及群公钥后确定签名是否有效的算法。

(5) 打开：在给定一个签名及群私钥的条件下确定签名人身份的算法。

因此在群签名算法实现的具体过程中有着巨大的挑战和难度,当然更为重要的是我们有着智能卡这个本身提供了一系列保护机制的载体,可以通过智能卡的安全机制来巧妙的实现密钥的导出。

我们首先确定密钥的导出条件,即需要三张智能管理卡,这三张管理智能卡分别由公司的高层管理者所拥有。为了保证发卡的统一过程,这三张智能卡与其他的普通用户卡一同由智能卡管理者发放,内部结构也基本相同,除了可以用作普通卡以后,唯一多出的功能就是拥有密钥导出的功能。

管理员拥有管理卡的发卡功能,因此需要对管理卡的发行进行一定的限制,这里采用的机制是管理员最多只能发行三张管理智能卡,而且智能卡的删除必须有三张管理卡的验证才能进行。三张管理智能卡相当于一个密钥链,每一张管理智能卡只能打开链上的某一环节,只有同时拥有三张管理智能卡而且知道智能卡的用户口令才能够对数据库中的密钥进行操作。图6-3对此机制进行了一些描述:

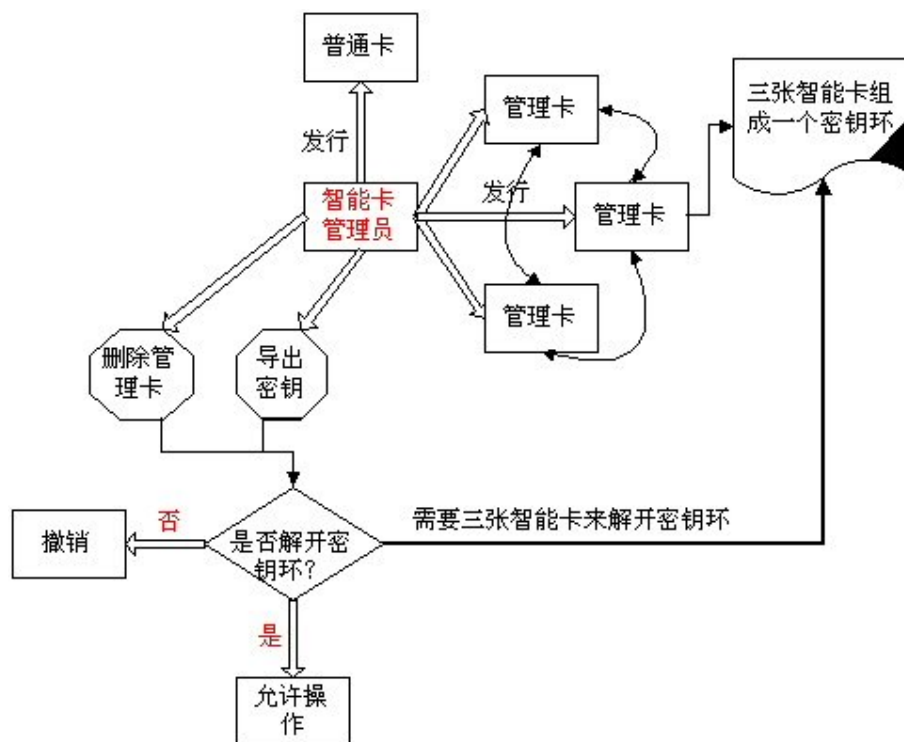


图6-3

第七章 总结与展望

本文的意义是在大量的工程实践基础上，将智能卡技术和证书技术应用到系统安全中，提出了基于智能卡的身份认证和访问控制技术，并加以初步的实现，对智能卡的实用化起到积极作用。

本文的主要工作和创新点可以总结如下：提出选用内置用户名和密码的登录措施，并扩展使用公钥证书来代替传统的用户名和密码方式。设计与实现了基于智能卡的安全登录系统，重点讨论了客户端图形化交互界面 GINA，它对智能卡的运用，采用一系列身份认证技术，有效地避免非授权用户对于计算机资源的非法访问，从而使操作系统的安全性得到改善。提出了智能卡插拔锁定以及管理员身份认证等具体实现方法。

在我们的系统中，硬件采用低成本、便携带、易使用的 USB 卡设备。网络管理员为每一位要登录网络中某台机器的用户颁发一个 USB 卡，卡内存放着该用户的数字证书。系统根据从硬件中读取的用户信息和用户输入的密码来判断用户身份的合法性。这种基于硬件的双因子验证方式可以方便地和其它认证系统结合使用，极大的提高了系统的安全性。

就本文的研究而言，还有许多方面有待于进一步改进。其中最重要的一点就是：GINA 的可扩展性和灵活性都存在着许多不足之处，主要表现在：接口繁多，扩展困难，调试不便。今后拟采用中间件的思想来拓展 GINA 的功能。

参考文献

- [1] Ben Hutz, Jack Fink. The Essentials of Replacing the Microsoft Graphical Identification and Authentication Dynamic Link Library. Microsoft Corporation Published June 2001
- [2] Internet Security Systems 公司. Windows2000 安全技术参考. 北京 机械工业出版社, 2001
- [3] Microsoft Platform SDK Documents
- [4] David A. Solomon, Mark E. Russinovich. Windows2000 内部揭密. 北京：机械工业出版社，2001
- [5] Roberta Bragg, 《Windows 2000 安全技术》，清华大学出版社，2002—1
- [6] William Stallings, 密码编码学与网络安全：原理与实践，杨明，胥光辉等译，电子工业出版社，2001
- [7] Peter Norton, Mike Stockman, 网络安全指南，潇湘工作室译，人民邮电出版社，2000
- [8] Mrike Kaeo, 网络安全性设计，潇湘工作室译，人民邮电出版社，2000
- [9] Bruce Schneier, 网络信息安全真相，昊世忠，马芳译，机械工业出版社，2001
- [10] 黄元飞，陈麟，唐三平，信息安全与加密解密核心技术，浦东电子出版社，2001
- [11] 袁津生，吴砚农，计算机网络安全基础，人民邮电出版社，2001
- [12] 吴旭华，Windows NT 驱动程序设计基础，人民邮电出版社，2000
- [13] 钱爱英. 智能卡技术[M]. 北京:清华大学出版社,1996: 161-184.
- [14] 李国新,杨肇敏,张忠会. 密码技术在智能卡中的应用[J]. 计算机工程与应用, 2000;(3): 60-61.
- [15] Mambo M, Usuda K, Okamoto E. Proxy signatures for delegating signing operation[A]. Proc. 3rd ACM Conference on Computer and Communications Security[C]. New York, NY, USA: ACM Press, 1996: 48-57.
- [16] Mambo M, Usuda K, Okamoto E. Proxy signatures : Delegation of the power to sign messages[J]. IEICE Trans. Fundamental, 1996; E79-A (9): 1338-1354.
- [17] 王育民,刘建伟. 通信网的安全——理论与技术[M]. 西安:西安电子科技大学出版社,1999: 193-199, 296-297.
- [18] Seungjoo K, Sangjoon P, Dongho W. Proxy Signatures, Revisited [A]. Proc. of ICICS '97[C].Springer Verlag, 1997: 223-232.
- [19] 王育民,何大可. 保密学——基础与应用[M]. 西安:西安电子科技大学出版社,1990: 60-66

致 谢

在本文完成之际，我由衷地感激给我关怀、教诲、帮助，支持和鼓励我完成学业的老师、亲人和朋友。

首先要感谢我的导师张申生教授。在硕士学习期间，他在学习和科研工作上一直对我悉心指导和热情鼓励，为我创造了很多锻炼提高的机会，在生活上也给予我极大的帮助和热心的关怀。张老师渊博的知识、宽广无私的胸怀、严谨求实的工作态度、对事业的执著追求、诲人不倦的教育风范和对问题的敏锐观察力，都使我受益匪浅，也是我终生学习的榜样。特别是张老师提倡的务实的学习模式，和无私奉献的精神，已经并且将在今后的工作与生活中令我们永远受益。在此我谨向敬爱的导师致以最诚挚的谢意。

还要对王英林老师、何援军老师、步封林老师、曹健老师、唐业博士等对我在科研过程中的指点和帮助表示感谢。尤其对唐业博士表示感谢，在他的指导下，参与并完成了一个个科研项目，同时，他对于我学习和生活上无微不至的关怀与帮助令我感到了无比的温暖和激励。从他身上我学到了许多对我今后的工作和生活都大有裨益的东西。

感谢实验室的所有师兄、师姐、师弟和师妹们：黄鹤远、牟玉洁、张建宏、韩松乔、张勇、张静宜、戴伟、徐文华、刘英华、罗建强、苏赫峰等，和他们共同经历的日子给我留下了美好的回忆。

感谢在读研的日子里一直陪伴着我、鼓励着我的朋友们：葛来皓、任锐、陈俊超、邵纯、曾晖、祝骅等等。

最后，衷心感谢我的父母以及所有亲人多年来对我的鼓励和支持，是他们多年的教诲、全力的支持和无私的爱激励着我在学业上不断进取，人格上不断完善。

攻读硕士学位期间的科研与学术论文

科研项目

- 1 软件质量开发管理平台 SPDM 的设计与开发 (2003.7- 2003.12)。
- 2 基于智能卡的安全登录系统的设计与开发 (2002.6-2003.10)。

学术论文

- 1 张帆, 张申生, 唐业, 戴伟, 基于智能卡的安全登录系统的设计, 已录用, 信息安全与通信保密。
- 2 戴伟, 张申生, 张帆, 基于智能卡的一种文件加密方案, 已录用, 计算机仿真。

上海交通大学 学位论文原创性声明

本人郑重声明：所呈交的学位论文，是本人在导师的指导下，独立进行研究工作所取得的成果。除文中已经注明引用的内容外，本论文不包含任何其他个人或集体已经发表或撰写过的作品成果。对本文的研究做出重要贡献的个人和集体，均已在文中以明确方式标明。本人完全意识到本声明的法律结果由本人承担。

学位论文作者签名：

日期： 年 月 日

上海交通大学 学位论文授权使用授权书

本学位论文作者完全了解学校有关保留、使用学位论文的规定，同意学校保留并向国家有关部门或机构送交论文的复印件和电子版，允许论文被查阅和借阅。本人授权上海交通大学可以将本学位论文的全部或部分内容编入有关数据库进行检索，可以采用影印、缩印或扫描等复制手段保存和汇编本学位论文。

保密☐，在____年解密后适用本授权书。

本学位论文属于

不保密☐。

(请在以上方框内打“√”)

学位论文作者签名：

指导教师签名：

日期： 年 月 日

日期： 年 月 日